

域名系统递归解析服务安全技术综述：风险、防护和测量

李沁心^{1,2} 武文浩^{1,2} 王兆华³ 李振宇^{1,2}

¹(中国科学院计算技术研究所 北京 100190)

²(中国科学院大学 北京 100049)

³(中国科学院计算机网络信息中心 北京 100083)

(liqinxin23s@ict.ac.cn)

Survey on DNS Recursive Resolution Service Security Technology: Threats, Defenses, and Measurements

Li Qinxin^{1,2}, Wu Wenhao^{1,2}, Wang Zhaohua³, and Li Zhenyu^{1,2}

¹(Institute of Computing Technology, Chinese Academy of Sciences, Beijing 100190)

²(University of Chinese Academy of Sciences, Beijing 100049)

³(Computer Network Information Center, Chinese Academy of Sciences, Beijing 100083)

Abstract The domain name system (DNS) recursive resolving service acts as a bridge between users and upstream DNS authoritative servers to enable users to conveniently resolve domain names through local DNS servers. However, as the first gateway for communication with users, DNS recursive resolving services have become a significant target for attacks on Internet infrastructure. Given the vast scale and variety of DNS recursive service deployments, current DNS security enhancements struggle with implementation complexity and compatibility issues. Despite its importance, there is a noticeable lack of research focused on the deployment of security protection mechanisms for DNS recursive services, as well as the comprehensive assessment of the associated security threats. To bridge this gap, we categorize the security risks associated with DNS recursive services into five main types: cache poisoning, DNS hijacking, direct attacks on recursive servers, leveraging recursive servers to target other servers, and exploiting software vulnerabilities. Additionally, we provide a summary of the latest research on DNS recursive service security threats and DNS security enhancement mechanisms. Our review also summarizes measurement methods for assessing the security risks. Finally, we analyze the current state of DNS recursive service security and offer insights into future research directions for improving the security monitoring and governance of DNS recursive services.

Key words domain name system (DNS); recursive resolution service; network measurement; security threat assessment; DNS recursive security

摘要 在域名系统 (domain name system, DNS) 中, DNS 递归解析服务消除了用户与根域名服务器等上游 DNS 服务器之间的复杂交互, 使得互联网用户可以方便地通过本地 DNS 服务器完成全球范围的域名解析。作为直接与用户通信的第一门户, DNS 递归解析服务过程已成为互联网基础设施攻击的一个重要目标。由于 DNS 递归解析服务规模庞大且部署方式繁多, 现有的 DNS 安全拓展机制在 DNS 递归解析服务器中存在部署复杂、兼容性差等问题, 但是目前还缺少对安全防护机制的部署测量方法的研究与总结工作, 缺乏针对 DNS 递归解析服务安全风险的系统全面的评估工作。针对上述现状, 将 DNS 递归解析服

收稿日期: 2024-03-12; 修回日期: 2024-12-09

基金项目: 国家重点研发计划项目 (2022YFB3103000)

This work was supported by the National Key Research and Development Program of China (2022YFB3103000).

通信作者: 王兆华 (wangzh@cnic.cn)

务存在的安全风险分为五大类,对 DNS 递归解析服务安全威胁、DNS 安全拓展机制和 DNS 递归解析服务安全风险评估与测量等方面的现状与最新研究成果进行了归纳与总结,并对 DNS 递归解析服务安全监测与治理的潜在研究方向进行了展望。

关键词 域名系统;递归解析服务;网络测量;安全风险评估;DNS 递归安全

中图法分类号 TP311

DOI: 10.7544/issn1000-1239.202440158 **CSTR:** 32373.14.issn1000-1239.202440158

域名系统(domain name system, DNS)作为互联网的关键基础设施,主要功能是提供域名和 IP 地址的映射解析服务,其稳定和安全的运行对整个互联网的正常工作至关重要。在 DNS 系统中, DNS 递归解析服务扮演着用户和权威域名服务器之间通信桥梁的角色。递归解析服务消除了用户与根域名服务器等上游 DNS 服务器之间的复杂交互,使得互联网用户可以方便地通过本地 DNS 服务器完成全球范围的域名解析。它准确地传递和解析用户的域名查询请求,是支撑整个 DNS 系统正常工作的基石。

然而多年来, DNS 递归解析服务持续面临着各种网络攻击的威胁。国内外安全机构的报告显示, DNS 递归解析服务过程已成为互联网基础设施攻击的一个重要目标,这给 DNS 递归解析服务的稳定运行带来巨大安全隐患。为保护 DNS 递归解析服务的安全和互联网用户的利益,国内外学者针对 DNS 递归解析服务可能存在的安全性问题展开了大量研究, DNS 递归解析服务的安全监测和治理已成为国际社会共同关注的重要课题之一。

自 1987 年 DNS 的核心 RFC 标准 RFC1034^[1]和 RFC1035^[2]制定以来,互联网工程任务组(Internet engineering task force, IETF)陆续制定和发布了 310 余篇与 DNS 相关的标准化文件,以完善和加强域名系统的各项安全机制。这些标准涵盖了密码学保护、安全扩展、新协议等多方面内容。与此同时,工业界也设计开发了稳定安全的 DNS 服务器软件,如广泛使用的 BIND、轻量级的 Dnsmasq 等。业界还结合不同攻击场景和安全风险,提出了一系列针对性强的攻击防护与缓解手段,如响应速率限制等。为方便用户获得安全稳定的 DNS 服务,一些大型互联网公司搭建了开放的公共 DNS 系统,如 Google Public DNS, OpenDNS 等。

但是,由于工业界对 DNS 递归解析服务安全风险的认识不足,大量安全机制的部署情况不容乐观, DNS 递归解析服务过程经常被暴露在缺乏保护、易受包括 DNS 劫持、缓存污染、拒绝服务等多种攻击

的危险环境中。因此,归纳总结 DNS 递归解析服务过程中易遭受的常见攻击、现存有效的 DNS 安全机制以及这些 DNS 安全机制部署情况的测量方法,有助于学术界与工业界认识 DNS 递归解析服务安全现状以及可能的治理方向。

目前国内外已有很多工作关于 DNS 安全风险进行了综述。Callejo 等人^[3]针对全球 DNS 递归服务器基础设施结构与流量进行测量分析,但是没有对 DNS 递归安全风险进行深入探讨;Khormali 等人^[4]从数据收集方法、数据分析技术和数据分析范围 3 个角度对 DNS 系统的安全与隐私问题进行综述,但该综述没有归纳梳理常见的 DNS 安全机制;Toorn 等人^[5]详细论述了 DNS 域名系统的组成,但仅介绍了部分重要的 DNS 安全扩展机制;Grothoff 等人^[6]探讨了有限的几种保障 DNS 递归服务机密性与完整性的安全机制对常见 DNS 安全风险的作用,对安全机制的总结尚不完备;Zou 等人^[7]重点综述了常见的 DNS 安全风险类型及其缓解手段,但没有涵盖全部缓解手段且没有综述缓解手段的配置测量方法;Kim 等人^[8]梳理了 DNS 域名系统的攻击漏洞以及部分主要缓解措施在填补漏洞与防御攻击上的作用,但没有归纳总结这些措施的部署情况及测量方法;Schmid^[9]对 DNS 系统面临的安全风险问题进行了全面详细的综述,并介绍了有限的几种 DNS 安全机制和一些 DNS 系统的替代方案,但没有讨论这些 DNS 安全机制的缓解能力以及它们的部署测量方法;王文通等人^[10]重点论述了针对 DNS 系统脆弱性的安全增强方案,但没有系统总结这些安全增强方案面对各种 DNS 递归解析服务攻击时的防御能力;张曼等人^[11]主要对 DNS 信道传输加密技术的实现原理及应用现状等进行综述,但缺乏针对这些加密技术部署情况测量方法与部署现状的总结归纳;张宾等人^[12]重点论述了 DNS 递归侧的安全风险以及相应的攻击检测方法和部分安全增强方案,但没有总结归纳常见 DNS 递归解析服务攻击与安全增强方案之间的对应关系以及安全增强方案的部署测量方法。综上,目前仍缺乏对

DNS 递归解析服务安全防护技术测量方法的分析综述,从安全防护技术出发分析评估递归解析服务的安全风险和面对各种安全攻击时的防御能力仍是目前的研究空白。

1 背景

1.1 DNS 递归解析服务

DNS 系统作为全世界最大的分布式服务器之一,承担着为全球互联网用户提供域名解析服务的任务。DNS 系统通过给每一个客户端配置一组指定的 DNS 递归解析服务器来给全球用户提供 DNS 域名解析服务。

DNS 递归解析服务指从客户端发送域名解析请求到客户端接收到域名解析结果的全过程。如图 1 所示, DNS 递归解析服务通常由 DNS 递归服务器池提供。DNS 递归服务器池具有复杂的 2 层以上的层次结构,它通常由面向客户端的 DNS 转发服务器、DNS 递归服务器入端口、面向权威端的 DNS 递归服务器出端口,以及隐藏在二者之间的 DNS 隐藏服务器和缓存记录共同组成。

客户端仅需要向面向客户端的 DNS 递归解析服务器或 DNS 转发服务器发送域名解析请求,并等待 DNS 递归解析结果即可。而对于 DNS 递归解析服务器来说,多数 DNS 递归解析服务器配置了 DNS 缓存,用来缓存在生存时间内的历史域名解析结果。DNS 递归解析服务器接收到域名解析请求,首先查找自身 DNS 缓存进行匹配,若请求结果在缓存中,则直接返回缓存中的结果;否则向 DNS 权威端进行 DNS 迭代查询。

DNS 递归解析服务器仅永久记录 13 台根服务器的 IP 地址,因此当 DNS 递归解析服务器接收到需要迭代查询的解析请求时,首先向根服务器询问域名的解析结果,根服务器返回 DNS 递归解析服务器带解析域名所属顶级域服务器的 IP 地址;DNS 递归解析服务器再迭代查询顶级域服务器,得到解析域名 2 级域服务器的 IP 地址;依次向下,直至域名所属的最小子域服务器返回最终的域名解析结果给 DNS 递归解析服务器,迭代查询结束。本文关注的正是 DNS 递归解析的全过程,包含参与 DNS 递归解析服务的全部 DNS 递归端服务器、客户端—DNS 递归端链路和 DNS 递归—权威端链路。

由上可知,递归解析服务连接用户和各级权威解析服务器,是互联网服务与网络之间映射“桥梁”的入口。互联网中的 DNS 递归解析服务器数量高达几十万到几百万量级,递归解析服务每日的查询规模高达万亿次^[3,13-15]。随着互联网网站、移动互联网等各种应用的数量激增,未来递归解析流量将持续高速增长,递归解析服务的安全稳定运行的重要性持续提升。

1.2 DNS 递归解析服务面临的安全风险

DNS 递归解析服务时刻面临恶意攻击者带来的安全威胁。在 IDC^[16]发布的《2022 年全球 DNS 威胁报告》中指出,88% 的组织在 2022 年中遇到 DNS 安全威胁,相关运营机构平均每年遭受 7 次安全攻击。近 10 年来,多家大型运营机构的递归解析服务遭受严重攻击,导致正常域名服务出现异常,严重危害了广大互联网用户的利益。例如 2014 年 1 月,由于中国通用顶级域域名解析出现异常,许多网站域名被解析到完全没有反应的 IP 地址 65.49.2.178,中国大陆爆发

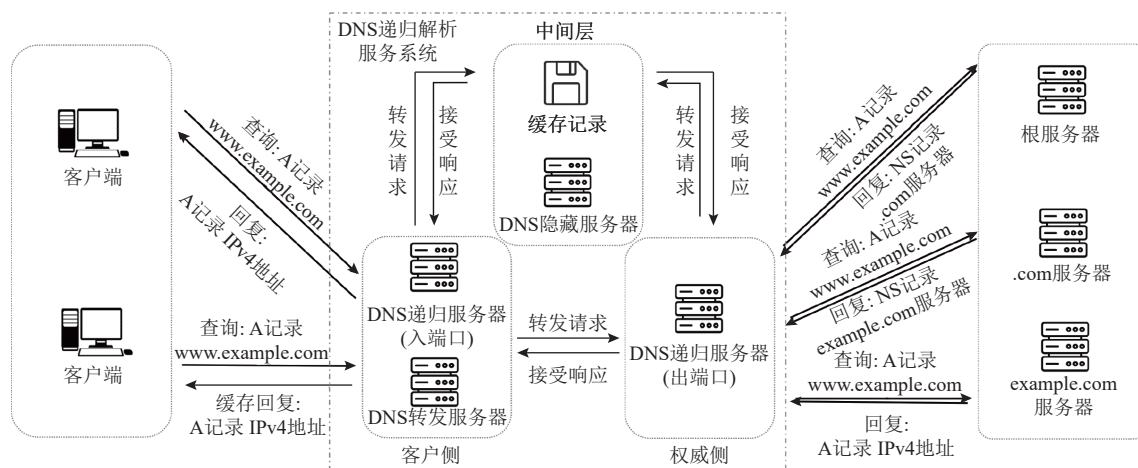


Fig. 1 DNS recursive resolution service process

图 1 DNS 递归解析服务流程

了大范围的网络故障^[17]; 2018年4月, 攻击者针对AWS route53 DNS服务器发起BGP路由劫持攻击, 导致访问用户被重定向到由黑客控制的恶意假冒网站, 造成严重的虚拟货币盗取等经济损失^[18]; 2023年10月, Galxe遭受DNS劫持攻击, 黑客通过修改Galxe.com的NS记录, 将网站访问者重新路由到欺骗性网络钓鱼网站, 导致1120名用户受到影响, 约27万美元被盗^[19].

鉴于DNS递归解析服务安全威胁给社会造成了重大经济财产损失以及不良社会影响, 国内外学者提出了大量保护DNS递归解析服务安全可靠性的DNS安全扩展机制. 这些机制通过弥补传统DNS协议的不足阻断攻击进程和缓解DNS安全攻击带来的不良影响(如增强身份认证、增强隐私性保护等). 虽然其中的部分安全机制得到了标准化, 但更多的是以学术论文、工具包或者实施指南等形式发表, 如图2所示, 本文列举了历史上影响力较大和较为流行的DNS安全扩展机制及其发布时间. 这些DNS安全机制中, DNS-0x20 encoding、TXID和源端口号随机化、DNS cookies等主要从引入随机变量的角度保障DNS安全; DNSSEC, DNS-over-TLS, DNS-over-HTTPS, DNS-over-QUIC, DNSCurve, DNSCrypt等则从数据加密和数字签名的角度保障DNS数据在传输信道上的机密性和完整性; 而源地址认证、响应速率限制等则通过过滤异常IP的流量来降低DNS递归服务器的流量负载.

虽然目前已有众多的DNS安全扩展机制为递归解析服务安全防护提供了重要的技术手段, 但由于DNS递归解析服务庞大的用户规模及复杂的部署实现, 现有安全机制存在部署复杂、兼容性差、缺乏标

准化部署方案等问题. 目前还缺少对递归解析服务安全防护机制部署情况测量研究的系统性总结工作, 缺乏针对DNS递归解析服务安全风险的系统的全面评估工作.

2 DNS递归解析服务安全风险

本节针对客户端—递归解析服务—权威服务器的系统结构, 根据安全风险在通信过程中的作用原理和攻击造成的影响, 将DNS递归解析服务安全风险分为缓存污染、DNS劫持、直接破坏递归解析服务器、利用递归解析服务器攻击其他服务器、软件漏洞利用五大类. 如图3所示, 攻击者利用DNS递归解析服务系统各环节中存在的安全漏洞实施攻击. DNS数据明文传输和缺乏身份认证机制以及完整性保护通常被用于缓存污染和DNS劫持攻击; DNS软件系统自身存在的漏洞可能被攻击者利用并进行非法系统入侵; DNS递归解析服务是拒绝服务攻击的实施手段及攻击目标, 攻击者利用DNS服务器缺乏流量访问控制机制以及对恶意流量缺乏鉴别能力等DNS流量控制漏洞, 实施直接破坏递归解析服务器的攻击和利用递归解析服务器攻击其他服务器的攻击, 且部分攻击者会利用DNS安全机制构造放大器实施高强度、低开销的反射放大攻击破坏其他服务器.

2.1 缓存污染

DNS缓存污染攻击是一种直接作用于DNS递归解析服务器缓冲区的DNS攻击形式, 如图4所示, 在该攻击中攻击者以客户端或递归解析服务器端缓存为攻击目标, 先于合法服务器响应伪造应答报文, 把恶意信息注入受害者服务器缓存, 达到在缓存生存

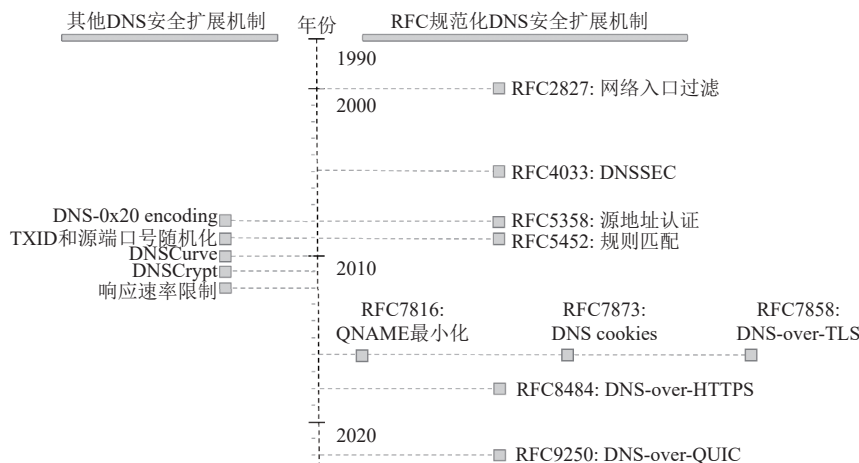


Fig. 2 Historical DNS security extension mechanism

图2 历史DNS安全扩展机制

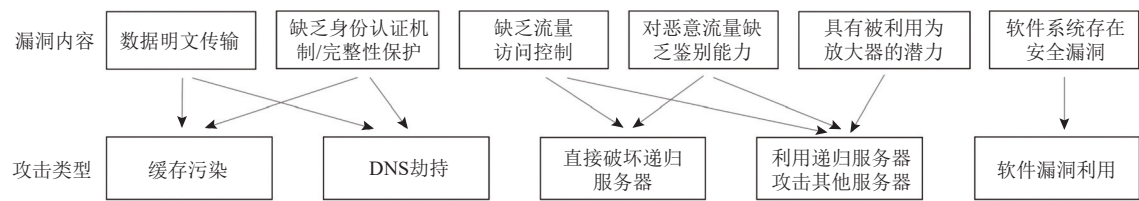


Fig. 3 DNS recursive resolution service system security vulnerabilities and attack types
图3 DNS递归解析服务系统安全漏洞与攻击类型

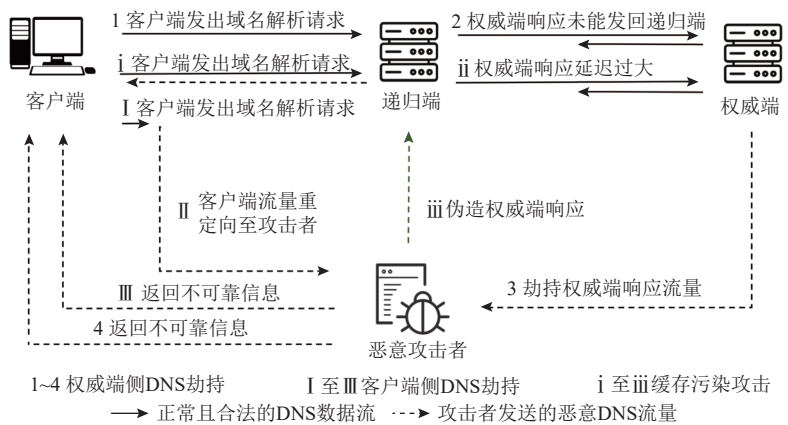


Fig. 4 DNS hijacking and cache poisoning attacks
图4 DNS劫持与缓存污染攻击

周期内重定向用户至攻击者所属IP的攻击目标^[20]。

缓存污染这类依靠伪造DNS响应流量、修改DNS递归解析服务器缓存,实现对客户流量重定向的攻击的实现基础是由于传统的DNS流量在封装数据时缺乏对敏感数据的保护,DNS数据不仅以明文方式传输,而且没有任何针对数据源认证和数据完整性保护的安全机制。传统DNS设计上的这2个安全漏洞导致DNS流量一旦被截获很容易被攻击者理解,且攻击者容易伪造出可被DNS递归解析服务器接收缓存的恶意流量。

缓存污染攻击的实现方法非常丰富多变,如表1所示,攻击者可以采用多种手段达到把错误响应注入目标服务器的目的。

Table 1 Types of Cache Poisoning Attacks
表1 缓存污染攻击类型

实现方法	伪造字段	代表性攻击
TXID与源端口号去随机化	ANSWER字段	侧信道攻击
伪造权威区和附加区的信息	NS记录	Kaminsky攻击 MagainotLine攻击
递归解析服务器中实现分片嫁接	ANSWER字段	分片重组攻击
BGP前缀劫持	ANSWER字段	BGP劫持攻击

直接伪造可被DNS递归解析服务器接受的解析应答报文是一种最常见的缓存污染攻击形式。2008

年发现的Kaminsky^[21]漏洞,是第1个通过伪造权威区与附加区信息一次性大范围攻击污染整个下属子域的缓存污染攻击手段。Kaminsky攻击通过恶意询问不存在的子域名,减少缓存生存时间带来的时间浪费,还通过伪造权威区和附加区的记录,缓存污染整个子域权威端IP地址,致使之后所有此域下的解析在缓存有效期内都会重定向至攻击者域,造成严重安全威胁^[22]。

区别于Kaminsky攻击污染下级域的NS记录,MagainotLine攻击开启了反向污染上级域的先河。MagainotLine攻击联合下游恶意权威端域名服务器伪造上游合法域的NS记录,并将伪造记录注入DNS递归解析服务器,实现对目标域的缓存污染攻击^[14]。与Kaminsky攻击相比,MagainotLine攻击以子域伪造父域NS记录的攻击形式,攻击了更多的二级域,进一步扩大了攻击面。

TXID与源端口号随机化是目前最为普及的应对DNS缓存污染攻击的安全机制之一。该安全机制通过引入5位随机数,降低攻击者正确猜测DNS响应数据的概率,抵御离途攻击者发起的缓存污染攻击。攻击者为对抗随机化技术,发展出以侧信道攻击为代表的一批去随机化攻击手段,通过破解随机化过程中硬件设施泄露的信息,来推断随机数的具体数值

以实现 TXID 和源端口号去随机化的攻击目的^[23]。

利用 DNS 数据传输过程中的参与数据包转发的网络中间设施,是与直接伪造 DNS 流量截然不同的攻击思想。攻击者利用中间设施的协议漏洞等,向目标 DNS 递归解析服务器注入精心设计包装的恶意信息。

利用大载荷数据在网络转发过程中的分片重组漏洞是一种行之有效的攻击形式。Zheng 等人^[24]利用 DNS 应答报文的第 2 分片报头简省的特点,向 DNS 转发服务器注入恶意 DNS 记录的第 2 分片后,再把合法响应强制分片,达到在 DNS 转发服务器中合成并缓存非法记录的目的;Brandt 等人^[25]利用 DNS 服务器中普遍存在的 DV(domain validation)漏洞在 DNS 递归服务器中实现分片重组攻击,完成缓存注入。文献^[24-25]虽然都围绕分片重组攻击展开,但二者作用的服务器不同且利用的机制漏洞也有区别。

BGP 前缀劫持则是在边境网关上做手脚。攻击者使用伪装的 AS 来伪造一个到目标 DNS 递归解析服务器所属 IP 前缀更短的路径,把流向目标 DNS 递归解析服务器的域名解析响应流量重定向到攻击者处,创造伪造流量数据的有利条件^[26]。

2.2 DNS 劫持

与 2.1 节的缓存污染攻击类似, DNS 劫持通过修改流量数据信息实现对受害用户的流量重定向攻击。但是,与缓存污染攻击聚焦于构造可被 DNS 递归解析服务器接收的伪造响应不同, DNS 劫持发生在整个 DNS 递归解析服务过程中,通过截获并篡改 DNS 报文实现将用户访问流量重定向至攻击者服务器^[27]。

如图 4 所示, DNS 劫持既可作用于解析请求也可作用于解析应答。攻击者利用通信链路上的中间设备(如路由器、中间盒等)拦截合法用户的域名解析请求,再通过入侵权威端或通信链路上的中间设备操纵 DNS 响应和修改响应内容,将客户端重定向至其他域名网站。本节将 DNS 劫持攻击分为权威侧 DNS 劫持和客户端侧 DNS 劫持 2 类。

1) 权威侧 DNS 劫持

攻击者通过攻击权威端服务器和递归端—权威端通信信道实现针对 DNS 域名解析应答的劫持攻击。攻击者的攻击目的多样,一方面,攻击者攻击权威端的注册商或名称服务器,注入错误信息把客户端重定向至错误的界面,非法获取目标网站的用户信息^[28];另一方面,部分 ISP 运营商错误货币化 DNS 系统,擅自把域名查找失败的用户重定向到广告界面进行牟利^[29]。

攻击者的攻击方式多种多样。攻击者首先可以

通过入侵权威端服务器系统,如:攻击注册商并篡改 NS 记录,跨域接管权威端服务器。但该攻击手法会导致权威端服务器持有的 TLS 证书的 AS 域信息在短时间内发生变化,或攻击者伪造的证书异常。这些特征都有助于判断目标权威端服务器是否遭受了 DNS 劫持攻击^[29]。其次,在网络通信过程中,攻击者也可以在 DNS 递归—权威通信链路上实施 DNS 劫持攻击。在这种情况下,在途攻击者也可以依赖网络中间设备发起 DNS 劫持攻击。攻击者截获权威端发往 DNS 递归解析服务器的 DNS 响应流量,并根据自身利益需要对 DNS 流量中的解析结果具体内容或响应的生存时间等进行修改,将客户端重定向到恶意网站或削弱安全机制对 DNS 系统的保护效果^[30]。

2) 客户端侧 DNS 劫持

针对解析请求的 DNS 劫持,攻击者通常在通信链路上使用透明拦截或递归重定向的手段,截获域名解析请求流量,并根据攻击者自身的需求对请求流量内容进行收集和篡改,客户端因而不能得到正确的 DNS 响应。

被劫持的 DNS 解析请求流量在流量特征上与正常 DNS 解析请求流量存在区别。首先,由于攻击者持有的 DNS 递归解析服务器与受害者客户端通常不处于同一 AS 域,攻击者伪造的请求流量的源地址存在错误或伪造流量中包含的证书不可验证和不可信任^[31];此外,攻击者会把客户端重定向至受控的不知名和不被信任的 DNS 解析服务器,但正常情况下普通用户极少选择此类 DNS 服务器完成域名解析,而且与良性的国家拦截审查不同,遭受 DNS 劫持篡改后的响应流量中存在恶意的广告、虚假的升级信息、处于黑名单中的 IP 或网页信息等内容^[32]。

针对用户解析的 DNS 劫持可能发生在解析请求发送信道的不同地方,攻击者除了可能直接作用于客户端主机进行劫持,还可能对 DNS 解析请求报文发送信道链路上的多个转发节点中或中间设备进行劫持。发生在客户端上的 DNS 解析请求劫持通常导致客户端设置的指定 DNS 解析 IP 无效,即无论客户端选择哪一个 DNS 解析器,最终都会被攻击者在用户不知情的情况下直接重定向到自身的 DNS 解析器^[33]。Randall 等人^[34]具体观察了针对家庭路由的 DNS 拦截行为,分析了 ISP 拦截发生的链路位置并针对位于 CPE、ISP 中间盒和非 ISP 中间设备这 3 种中间转发设备劫持情况给出了具体的测量判断方法。

2.3 直接破坏递归解析服务器

开放 DNS 递归解析服务器不具备细粒度流量访

问控制的能力, 尽管通过访问控制列表可以实现一定程度的流量过滤, 其访问控制列表中通常包含大量攻击者可用的公网网段. 恶意攻击者可以轻易地通过网段内攻击设备向目标递归解析服务器发送大量查询; 另一方面 DNS 递归解析服务器缺乏鉴别异常流量的能力, DNS 递归解析服务器容易对异常的泛洪流量“照单全收”, 浪费大量计算资源、存储资源, 丧失为合法用户提供正常递归解析服务的能力.

根据攻击原理, 攻击者主要通过消耗带宽和占用 DNS 递归解析服务器缓存 2 种方式实施针对 DNS 递归解析服务器的直接破坏攻击, 常见的攻击类型如图 5 所示. 攻击者发送大量解析请求至目标 DNS 递归解析服务器, 递归解析服务器消耗大量资源处理异常请求, 导致合法客户端发起的解析请求以明显缓慢的速度被处理甚至无法响应.

1) 消耗带宽

NXDOMAIN 攻击是一种较常见的攻击形式. 攻击者发送海量各不相同且难以缓存命中的 UDP 解析请求, 如随机前缀, 至目标 DNS 递归解析服务器端, 致使 DNS 递归服务器进行大量递归查询解析这些恶意请求, 这种攻击形式消耗 DNS 递归解析服务器的带宽资源, 放缓甚至中断合法递归解析^[35], 降低网站、API 或 Web 应用程序针对用户合法流量的响应能力.

2) 占用缓存

恶意消耗服务器缓存是一种削弱 DNS 递归服务器服务能力的有效方式. NXDOMAIN 攻击和幻域攻

击是 2 种典型的应用. 前者在 DNS 递归服务器缓存中注入大量垃圾条目, 降低缓存的有效命中率, 拉低递归服务器解析速率; 后者诱导递归服务器查询大量响应极其缓慢的域名, 消耗请求等待资源, 使递归服务器无法正常服务合法用户.

NXDOMAIN 攻击利用权威服务器接收到不存在域的查询请求就会返回 NXDOMAIN 消息的特性^[36], 通过僵尸网络控制一批客户端发送大量不存在域的查询请求给目标 DNS 递归解析服务器, 导致目标 DNS 递归解析服务器的缓存被不存在域的 NXDOMAIN 记录填充^[37]. 处理大量恶意查询使 DNS 递归解析服务器无法正常执行递归查询, 缓存又进一步被恶意记录占满, DNS 递归解析服务器解析合法域名的能力被降到了最低, 甚至无法提供解析服务^[38].

与 NXDOMAIN 类似的还有幻域攻击^[8]. 实施幻域攻击的攻击者会申请一系列无法访问或者响应速度非常缓慢的域名, 并向目标 DNS 递归解析服务器发送大量针对这些域的查询请求. 由于递归服务器通常会预留足够的缓存资源等待响应数据, 大量访问响应时间过长甚至无法响应的域名会导致递归解析服务器浪费大量缓存资源, 造成面向客户端的合法请求速度缓慢甚至拒绝服务.

2.4 利用递归解析服务器攻击其他服务器

如图 5 所示, 攻击者针对 DNS 递归解析服务的泛洪攻击, 除了直接作用于 DNS 递归解析服务器本身, 还可以利用 DNS 递归解析服务器间接作用于 DNS

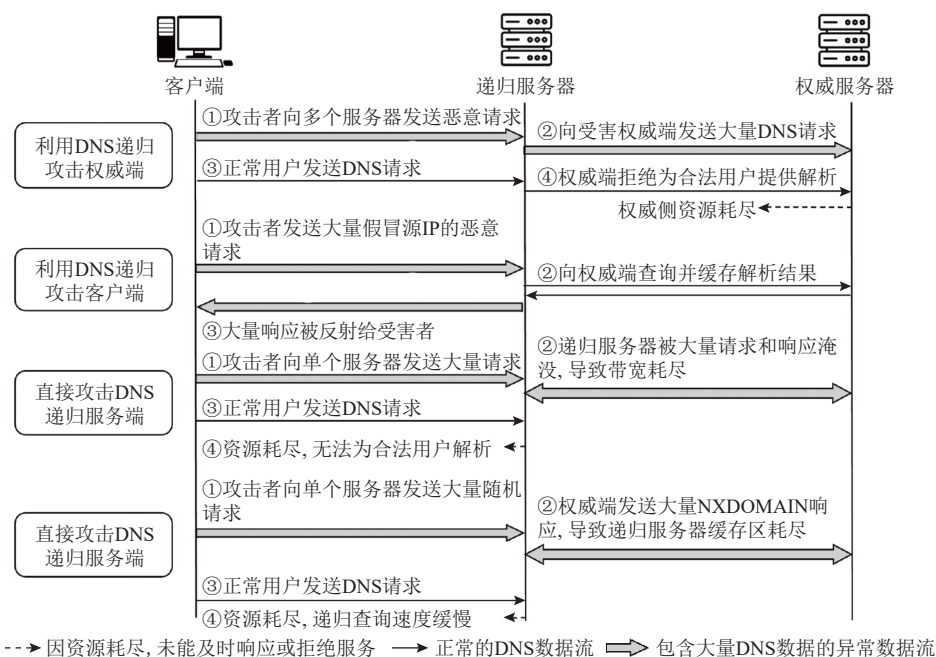


Fig. 5 Directly destroying a recursive resolution server and using a recursive resolution server to attack other servers

图 5 直接破坏递归解析服务器与利用递归解析服务器攻击其他服务器

递归解析链路上的其他服务器,比如客户端的主机以及用于提供针对某一特定域下名称解析服务的权威服务器.这类攻击与直接作用于DNS递归解析服务器的攻击一样,皆因DNS服务器缺乏识别异常流量的能力又缺乏访问控制机制,因此这2类攻击具有很多相似性.但是,除了受害服务器不同,二者最大的不同在于攻击者在利用DNS递归解析服务器攻击客户端时,可以利用DNS递归解析服务器配置的DNS安全扩展机制带来的安全隐患,以DNS递归解析服务器为放大器构建针对DNS客户端的拒绝服务攻击.

1) 破坏客户端

攻击者利用DNS递归解析服务器作为放大器,针对客户端执行反射放大攻击.如图5所示,攻击者控制僵尸网络中的大量客户机向递归解析服务器发送源IP为受害主机的伪造请求,递归解析服务器把大量放大响应报文反射回受害主机,消耗受害主机的宽带资源,并造成受害主机瘫痪^[39].由于缺乏源地址过滤机制,默认开放配置下的递归解析服务器较易被利用为放大器.而支持EDNS的开放DNS递归服务器,如果支持DNSSEC或允许TXT, ANY查询,由于可能带来高于4 000 B的DNS响应和实现70余倍的放大效果,更是攻击者的理想目标^[40].

近年来,还发现了很多其他危害性更大、放大倍数更强的DNS反射放大攻击.Duan等人^[41]发现了一组广泛存在于多个DNS服务软件中的可能遭致几百倍甚至上千倍放大系数的安全漏洞;Anagnostopoulos等人^[42]研究了TLD中ANS被利用为放大器的潜力,并证明它可能带来60倍的放大倍数;Nawrocki等人^[43]发现攻击者通常能检测到新的放大器,而且不遵循DNSSEC密钥滚动的最佳实践,带来更大的放大效果;Nosyk等人^[44]发现路由循环也会带来巨大的反射放大效果,他们观测到一个A记录查询最差可能导致6.55亿次响应.

2) 破坏权威端

如图5所示,攻击者利用DNS递归解析服务器向受害域的权威服务器发送大量域名请求,达到破坏权威端服务器,使其对合法请求响应缓慢甚至拒绝响应的攻击目的.攻击者常用的攻击方法有DNS泛洪攻击和随机子域名攻击.

DNS泛洪攻击利用DNS服务器无法区分正常的繁忙请求和DNS洪水攻击流量的弱点,向目标DNS服务器发送大量异常UDP请求,大量消耗目标DNS服务器的资源,让目标DNS服务器缓慢甚至不能响应合法UDP请求^[45].

随机子域名攻击是另一种形式的DNS泛洪攻击.区别于一般DNS泛洪攻击针对特定权威端服务器发送远超其处理范围的解析请求,随机子域名攻击是针对某一目标域请求大量不存在的子域名^[46].传统DNS系统中,DNS递归服务器缓存仅能命中完全相同的域名.域解析服务器因此需要大量处理这些递归服务器发来的大量仅前缀不同的域名,导致域解析服务器需要浪费大量资源多次遍历查询整个域用以查找这些不存在的子域,大大放緩了域解析服务器处理合法用户请求的速度.例如NXNSAttack^[47],攻击者向攻击者自身的服务器发送大量不同子域的查询请求,随后攻击者服务器响应大量带有多个伪造目标域NS记录的应答响应,迫使中间递归解析服务器执行海量针对受害域的递归查询,实现对中间递归解析服务器和受害域权威服务器的双重攻击.

Sommese等人^[48]通过观察2020年11月到2022年3月这17个月内发生的DDOS攻击,发现大多数攻击仅针对某一特定域名或特定网段,且尽管攻击数达到百万级,但显著增加了解析时间,甚至使域名不可达的情况非常少.

2.5 软件漏洞利用

国内外DNS递归解析服务器主要依靠安装配置流行的DNS软件来提供DNS服务.由于DNS服务软件系统庞大、功能复杂,DNS服务软件不可避免地存在可利用性与危害程度不一的各类安全漏洞.本文考察了CVE漏洞库^[49]中与DNS相关的457个漏洞.其中有部分漏洞通常被利用来构造本节前面介绍的其他安全攻击,比如:dnsmasq中的CVE-2020-25684容易引发缓存投毒攻击^[50];ISC BIND中的CVE-2020-8616具有被利用构造NXNSAttack攻击的潜力^[51]等.本节在前期介绍其他安全攻击时已经充分考虑了此类漏洞带来的安全问题.

本节主要分析总结近10年内与直接攻击入侵递归解析服务器DNS软件系统、影响破坏递归服务器DNS软件原始功能等相关的141个漏洞,并把其分为如表2所示的任意代码执行、访问控制绕过、攻击提权、信息泄露和程序崩溃;如Nginx DNS中的CVE-2021-23017漏洞,当管理员不当配置nginx文件时,可能带来拒绝服务攻击或任意代码执行攻击^[52];ISC BIND中的CVE-2022-0635漏洞可能导致服务器在经过一系列特殊请求后意外中断^[53]等.

如表3所示,据CVE漏洞库中收录的数据统计,截至2024年初的近10年内,在下述6个重点DNS递归服务软件中共发现141个直接入侵攻击DNS服务

Table 2 Types of DNS Software Vulnerabilities
表 2 DNS 软件漏洞类型

漏洞类型	危害威胁
任意代码执行	攻击者能够在目标主机或目标进程中执行任意命令或代码
访问控制绕过	攻击者绕过身份验证，获得访问权限
攻击提权	获取系统或应用的额外权限
信息泄露	用户或系统敏感数据泄露
程序崩溃	扰乱服务器功能，致使其不能正常为用户提供服务

软件与系统的漏洞。

考察这 6 个 DNS 服务软件的平均水平，若把这些安全漏洞按危害级别分类，90% 以上的漏洞为高危漏洞与中危漏洞，且高危漏洞占有比例普遍大于中危漏洞；按漏洞攻击类型分类，不同 DNS 服务软件的已知安全漏洞差异较大，其中，引起程序崩溃的安全漏洞最为普遍，占全部漏洞的 85% 左右。

考察这 6 个 DNS 服务软件的最新版本，这 6 个 DNS 服务软件均只存在少量或不存在安全漏洞。但是，从漏洞分数和漏洞分布角度看，与这 6 个 DNS 服务软件的平均情况差异不大。

3 常见的安全机制

虽然攻击手段层出不穷，DNS 服务系统软件存

在大量危害性不一的漏洞，但是每个类型的攻击通常都是利用 DNS 递归解析服务系统自身存在的有限的漏洞弱点对 DNS 递归解析服务进行破坏，而针对这些漏洞，目前提出了一系列 DNS 安全机制进行针对性的攻击防护。

基于安全机制提供保护的思想内核、基本原理和信息安全 3 个要素，本文将全部安全机制分为机密性保护、完整性保护和可用性保护这 3 类。又由于各 DNS 安全扩展机制作用位置不同，安全扩展机制可分为作用于通信信道、作用于服务器和作用于通信端口 3 类。DNS 安全扩展机制的具体分布情况如图 6 所示，本节将针对 DNS 安全扩展机制的不同作用位置，分别从机密性、完整性等方面对其进行梳理总结。

3.1 作用于客户端—递归解析服务器通信信道

部分 DNS 递归解析服务安全扩展机制的主要功能是重点保障 DNS 流量在客户端到 DNS 递归解析服务器端这个不可靠信道上的数据安全性，因此这类机制具有：1)需要客户端和 DNS 递归解析服务器端进行协商认证；2)除了客户端和 DNS 递归解析服务器这 2 台通信首尾的设备，其他离途或在途设备不能获取全部通信信息或不能伪造篡改流量数据或不能理解流量数据。

Table 3 Details of DNS Software Vulnerabilities
表 3 DNS 软件漏洞详细信息

软件	漏洞数	漏洞攻击类型									
		任意代码执行		访问控制绕过		攻击提权		信息泄露		程序崩溃	
		最新版本	平均水平/%	最新版本	平均水平/%	最新版本	平均水平/%	最新版本	平均水平/%	最新版本	平均水平/%
ISC BIND	36	(0, -)	5.60	(0, -)	2.80	(0, -)	5.60	(0, -)	2.80	(1, 7.5)	83.20
Unbound	7	(0, -)	0	(0, -)	0	(0, -)	0	(0, -)	0	(2, 7.5)	100
DNSmasq	17	(0, -)	17.60	(0, -)	0	(0, -)	0	(0, -)	5.90	(0, -)	76.50
Knot DNS	5	(0, -)	0	(0, -)	0	(0, -)	0	(0, -)	0	(1, 7.5)	100
PowerDNS	28	(0, -)	0	(0, -)	3.60	(0, -)	3.60	(0, -)	3.60	(1, 7.5)	89.20
Mikrotik	48	(0, -)	14.60	(0, -)	0	(0, -)	2.10	(0, -)	0	(0, -)	83.30

软件	漏洞分数		
	高危漏洞占比/%	中危漏洞占比/%	低危漏洞占比/%
ISC BIND	45.20	48.40	6.40
Unbound	70.00	30.00	0
DNSmasq	66.60	33.40	0
Knot DNS	78.60	21.40	0
PowerDNS	50.00	48.50	1.50
Mikrotik	43	57	0

注：漏洞攻击类型中，“平均水平”栏中所示数字为该漏洞类型在所有漏洞类型中的分布比例。“最新版本”栏中所示数字为最新版本中该类型漏洞数量及平均漏洞分数，表示为（漏洞数量，平均漏洞分数）。表中“（0，-）”的“-”表示软件在当前版本下不存在该类漏洞，所以平均漏洞分数也不存在。

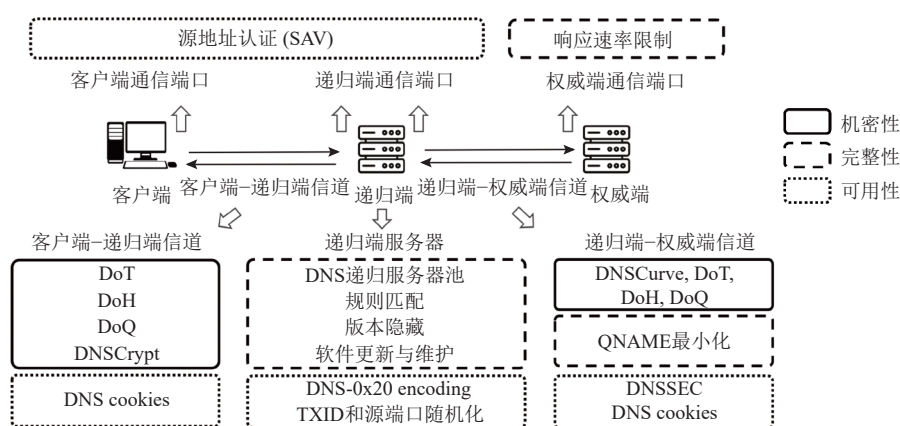


Fig. 6 DNS security extension mechanisms

图6 DNS安全扩展机制

3.1.1 机密性

安全扩展机制运用密码学工具对客户端—递归解析服务器通信信道上的流量进行加密,阻止在途攻击者通过中间设备截获DNS数据流甚至篡改数据.DNS递归解析系统既可以使用现有加密传输协议封装DNS流量数据,也可以使用密码学工具协商密钥直接对客户端—递归解析服务器通信数据进行加密封装.

1) DoT

DoT(DNS-over-TLS)协议由Zhu等人^[54]提出,DoT经常用以缓解针对DNS系统的缓存污染攻击.DoT默认在著名的853端口上建立基于TCP传输的TLS会话连接来加密DNS流量^[55].在DoT服务流程中,每次启动DoT会话都需要完成一次完整的TLS会话握手,之后通过TLS发送DNS数据并完成针对响应消息的身份认证.RFC8094^[56]针对DoT只能基于TCP传输实现的问题提出了DNS-over-DTLS,该协议可以基于UDP实现DoT服务.DoT虽然针对DNS流量进行了数据加密,但依旧存在信息泄露的风险,因为DoT使用专用的853端口完成数据传输,攻击者很容易根据端口号过滤得到DoT流量^[55].此外,Houser等人^[57]使用随机森林和Adaboost分类算法对大量使用TLS加密后的DNS流量进行模型训练研究,发现TLS加密并不能完全消除网络指纹技术对隐私问题造成的威胁,即依旧可以通过加密后的密文分辨用户是否访问了特定的网络信息.

2) DoH

RFC8484^[58]描述了基于HTTPS协议的DNS数据报文机密性传输协议,该协议规定DNS报文不再使用传统的53端口而是与其他HTTPS数据一样使用443端口,并对DNS数据流量进行HTTPS加密,实

现DNS数据从客户端发往服务器端过程中的隐私机密性.DoH(DNS-over-HTTPS)协议遵循HTTPS传输的通信规则,使用经过协商的特定URL模板实现DNS查询与响应.在高吞吐量与低丢包率的情况下,DoT/DoH的传输效率明显优于传统DNS^[59].

由于DoH加密的DNS流量与其他HTTPS流量共用一个443端口,DoH流量很容易混合在大量因为用户与网页交互产生的流量中,提高了DoH流量的隐蔽性,改善了DoT流量容易被过滤的问题.

3) DoQ

DoQ(DNS-over-QUIC)协议^[60]即DNS协议在QUIC传输上的映射,给DNS传输提供一种DNS响应的大小不受路径MTU限制的传输方案.DoQ可以提供与DoT相同的DNS隐私保护,且在延迟上与传统的UDP传输相近及在缩短中小距离传输时延上有突出优势^[61-62],在有效减少丢包率的同时还能提供更高级别的源地址验证.

部署DoQ可以有效保护用户隐私.TLS握手之后,QUIC不仅加密有效负载,还加密数据头字段,除了数据接收方,其他中间路径攻击者很难对DoQ加密后的DNS流量进行编辑^[63].但是,DoQ依旧存在隐私泄露的风险,Hu等人^[64]使用机器学习算法构造了针对DoQ加密流量分类的分类器模型,经过多轮训练,分类效果最好的ADT模型的分类成功率高达99%,这说明即便使用了DoQ对DNS进行加密,密文依旧有泄露用户信息的风险.

4) DNSCrypt

DNSCrypt协议^[65]可以使用UDP和TCP传输协议,且协议的默认端口应为443.客户端和解析器初始生成一个短期密钥对.如图7所示,DNSCrypt会话始于客户端向启用DNSCrypt的解析器发送未经

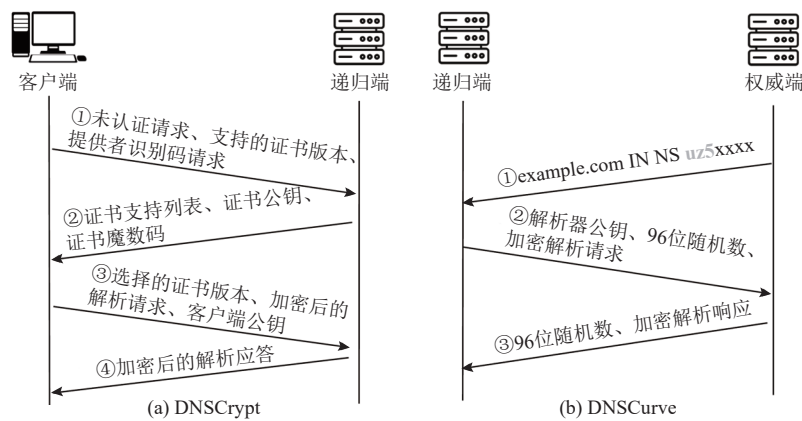


Fig. 7 DNSCrypt and DNSCurve

图 7 DNSCrypt 和 DNSCurve

身份验证的 DNS 查询. 由于一个解析器可以支持多种算法并提供多种算法的解析器公钥, 因此在解析器发送的一组公共签名证书响应中每个证书都包含一个幻数, 客户端必须使用该幻数作为其查询的前缀, 以便解析器知道客户端选择了哪个证书来构建给定的查询. 客户端使用选定的加密方案来发送加密查询, 解析器验证并解密查询, 并使用相同的参数对响应进行加密, 从而完成一次完整的基于 DNSCrypt 的加密查询过程.

3.1.2 完整性: DNS cookies

设置令牌可以在一定程度上缓解和防御作用于客户端—递归解析服务器通信信道上的攻击. 令牌帮助客户端或 DNS 递归解析服务器端对信道另一边的设备进行可靠身份验证, 缓解和防御由于攻击者假冒身份带来的安全威胁. DNS cookies^[66] 提供 DNS 请求和响应的轻量级消息身份验证, 不需要预配置每个客户端或服务端状态. DNS cookies 的使用可以为客户端和 DNS 服务器端提供针对对方源 IP 的认证保护.

DNS cookies 的工作流程如图 8 所示^[67].

①客户端在不清楚 DNS 递归解析服务器端 cookie

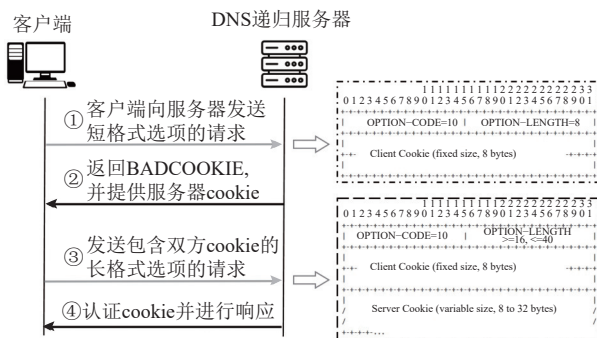


Fig. 8 DNS cookies communication

图 8 DNS cookies 通信

的情况下发送不包含 DNS 递归解析服务器端 cookie 的短格式选项请求, 否则直接从③开始通信;

② DNS 递归解析服务器端接收到短格式请求后, 返回 BADCOOKIE, 并提供自身最新的 cookie;

③客户端在知道 DNS 递归解析服务器 cookie 的情况下, 直接发送包含双方 cookie 的长格式选项请求;

④ DNS 递归解析服务器端对 cookie 的值进行认证, 若有效则信任客户端提供解析服务, 并在响应报文中提供生成的新 cookie 值, 为下次通信做准备.

3.2 作用于递归解析服务器—权威端通信信道

攻击者冒充合法权威端服务器发送伪造的 DNS 响应一直是递归解析服务器—权威端通信信道上非常突出的安全问题, 伪造的数据流量一旦被 DNS 递归解析服务器接收, 就会把伪造数据信息存入自身缓存中并发送给全部请求这一域名的客户端主机, 造成大范围的恶意域名重定向事故. 因此, 针对递归解析服务器—权威端通信信道的保护, 学术界从机密性、完整性和隐私保护这 3 个角度分别就防御重定向和隐私泄露问题提出了行之有效的 DNS 递归解析服务安全扩展机制.

3.2.1 机密性

1) DoT, DoH, DoQ

在 3.1 节中已经详细介绍了 DoT, DoH, DoQ 这 3 种网络加密传输协议在客户端—递归解析服务器通信信道上的重要作用. 与客户端—递归解析服务器端类似, 在递归解析服务器—权威端部署 DoT, DoH, DoQ 也可以提高该通信信道上 DNS 数据流量的机密性, 解决包括缓存污染、DNS 劫持等在内的各项 DNS 安全问题.

DoT, DoH, DoQ 在递归解析服务器—权威端的应用尚未得到大范围的推广应用. 但是, 近年来国际社会

已经推出或正在推进与之相关的国际技术标准^[60,68], 在未来递归解析服务器—权威端的 DoT, DoH, DoQ 的部署工作或将具有较大前景。

2) DNSCurve

DNSCurve 加密数据流, 使攻击者无法理解或构造合法 DNS 流量, 从而阻断 DNS 攻击的发生。DNSCurve 是一个拟议 DNS 安全协议。DNSCurve 使用 Curve25519^[69] 椭圆曲线加密来建立 Salsa20 使用的密钥, 并与 MAC 函数 Poly1305 配对, 以加密和验证解析器与权威服务器之间的 DNS 数据包。

如图 7 所示, DNSCurve 的通信流程从支持 DNSCurve 的权威服务器向 DNS 递归解析服务器返回具有特殊字符串前缀并包含 base255 编码的服务器公钥的 NS 记录开始。之后, DNS 递归解析器向权威服务器发送一个包含解析器自身 DNSCurve 公钥、一个 96 位随机数和一个包含查询请求的加密盒的数据包。权威服务器接收到来自 DNS 递归解析服务器的加密通信后, 使用自身私钥解密加密盒并把响应结果使用 DNS 递归解析服务器端的公钥加密封装成新的加密盒返回给 DNS 递归解析器^[70]。

DNSCurve 使用表 4 所示的防御措施, 对 DNS 服务器容易遭受的 4 种典型攻击类型提供安全性保护^[71]。

Table 4 DNSCurve Defense Principles and Related Attacks

表 4 DNSCurve 防御原理与相关攻击

使用方法	针对性攻击
加密 DNS 请求与响应	DNS 伪造、DNS 信息窥探收集
加密身份验证	DNS 记录伪造
过滤攻击者伪造的恶意 DNS 数据包	DNS 拒绝服务攻击
使用 96 位随机数、密文进行传输	重放攻击

3.2.2 完整性

1) DNSSEC

在递归解析服务器—权威端通信信道中, 截获并篡改响应流量或直接伪造响应流量是最常见的攻击形式, 因此对这段不可靠信道上的数据进行数据源认证, 即认证 DNS 响应流量来自合法的权威端服务器以及对流量数据内容进行完整性保护来保障数据内容完整至关重要。而在现行 DNS 系统中, 主要依靠 DNSSEC 安全扩展来完成上述 2 类完整性保护。DNSSEC 是以数字签名为主要思想来保护数据完整性和数据源认证的 DNS 安全扩展机制^[76]。

为使用 DNSSEC 安全扩展, 引入记录和密钥如表 5 所示。

如图 9 所示, DNSSEC 的验证主要在递归解析服

Table 5 DNSSEC Record Types and Key Types

表 5 DNSSEC 记录类型与密钥类型

类型	标记	意义
记录类型	DNSKEY	记录保存 ZSK, KSK 的公钥
	DS record	由父域 ZSK 私钥签名, 用以保护子域 KSK 公钥完整性
	RRSIG	KSK 私钥对 ZSK 公钥的签名, 保护 ZSK 公钥完整性
密钥类型	ZSK	区域签署密钥, 对域内各类型数据进行签名
	KSK	密钥签署密钥, 对 ZSK 公钥签名

务器中完成, 具体的验证过程如下:

①递归解析服务器接收到解析响应报文和来自权威服务器的数据记录 RRSIG; 递归解析服务器向权威服务器请求 ZSK 公钥的 DNSKEY;

②权威服务器返回 ZSK 的 DNSKEY 和用权威服务器 KSK 私钥签名的 ZSK 的记录 RRSIG;

③递归解析服务器向权威服务器请求权威服务器 KSK 公钥的 DNSKEY;

④权威服务器返回自身 KSK 公钥的 DNSKEY;

⑤递归解析服务器向上级域请求其子域的 DS 记录;

⑥上级域返回下级域的 DS 记录, 以及包含自身 ZSK 公钥的 DNSKEY;

⑦重复③~⑦步, 直至根域;

⑧从上至下验证公钥的完整性, 若验证正确, 则可使用权威服务器 ZSK 公钥验证数据内容完整, 没有被篡改, 且数据源为合法的权威服务器。

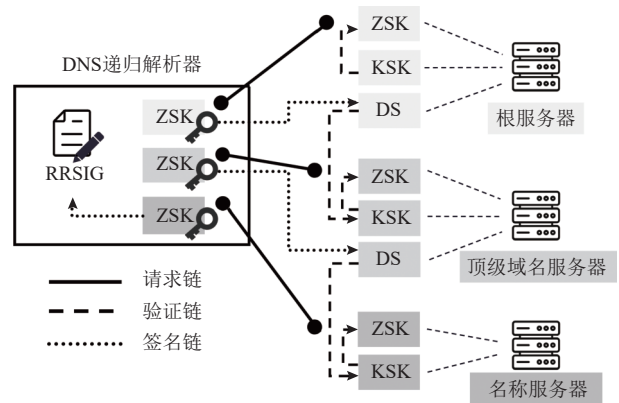


Fig. 9 Trust chain of DNSSEC

图 9 DNSSEC 信任链

NSEC^[77] 使用 DNSSEC 对不存在的域名进行拒绝存在认证, 即当用户查询某一不存在的域名如 a.example.com 但下一条存在的记录是 b.example.com 时, DNS 服务器返回针对 a.example.com 的 NXDOMAIN 记录并返回一条指向 b.example.com 的 NSEC 记录。

该特性即区域行走,被攻击者利用以探测整个域内的全部子域名.为解决这一问题,更安全的做法是选用通过返回下一域名哈希值而非明文,从而避免了区域行走的 NSEC3.

DNSSEC cache-validation^[36] 利用 DNSSEC 数据认证的优势,通过否认不存在域名所属的子域段,进一步防御 NXDOMAIN 攻击,尤其是缓解随机子域名攻击的影响.

虽然 DNSSEC 在保障 DNS 数据完整性上具有非常好的效果,但是 DNSSEC 具有部署复杂的缺点,因此很多域即使部署了 DNSSEC,也广泛存在部署配置不当的问题. Adrichem 等人^[78] 提出 73.9% 配置了 DNSSEC 的服务器存在配置错误的问题,排名前 3 的配置错误类型为:找不到 DNSKEY、KSK 被 ZSK 否认和服务端错误.除此之外还有 KSK 的 DNSKEY 被 DS 记录否认、服务器超时等常见的配置错误问题.

DNSSEC 也存在一些潜在的安全问题. DNSSEC 使 DNS 应答报文载荷量骤增,但是请求报文的载荷量却几乎没有变化,这导致配置了 DNSSEC 解析功能的递归解析服务器,尤其是可公开访问的开放 DNS 递归解析服务器,通常被攻击者视为可利用的放大器^[79]. 而关闭开放递归、设置访问速率限制和源地址认证等手段,可以降低此类反射放大攻击的安全风险.

2) DNS cookie

DNS cookie 不仅可以如 3.1 节所述部署在客户

端—递归解析服务器端,还可以部署在递归解析服务器—权威端.

在递归解析服务器—权威端通信信道上, DNS cookie 的双向认证令牌可以帮助递归解析服务器有效过滤离途攻击者伪造的错误响应,解决缓存污染等安全问题.

3.2.3 隐私保护: QNAME 最小化

提高 DNS 递归解析服务系统的隐私保护或减少隐私泄露问题,可以有效保护递归解析服务器—权威端通信信道的机密性. 信道上的安全问题与隐私泄露相关. 避免攻击者窃取完整的用户隐私信息,对缓解递归解析服务器—权威端信道上的安全问题有所帮助. QNAME 最小化遵循“发送的数据越少,隐私问题就越少^[72]”的原则,将 DNS 查询的内容限制为名称服务器在迭代解析过程中将请求者引用到下一个名称服务器这一工作所需的最小值来更改 DNS 解析过程,从而将解析器和名称服务器间的数据敏感性降到最低^[73]. RFC7816^[74] 指出,当 DNS 递归解析服务器接收到关于“www.example.com 的 A 记录是什么?”的查询请求时,将完整的问题发送给迭代查询过程中的全部权威服务器是一种传统,但是并不是协议要求. 如图 10 所示, QNAME 最小化通常以 QNAME 的内容仅比 DNS 服务器授权的区域多一个标签但 QTYPE 内容不变的方式完成^[75],即 QNAME 最小化是一种“DNS 解析器不再将完整的原始 QNAME 发送到上游名称服务器”的技术.

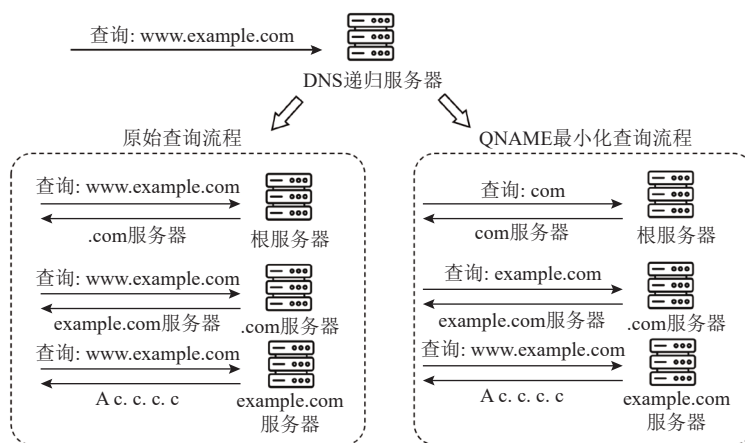


Fig. 10 Minimization principle of QNAME

图 10 QNAME 最小化原理

3.3 作用于 DNS 递归解析服务器

大量 DNS 安全扩展机制部署在 DNS 递归解析服务器上,因为在递归解析服务过程中,全部来自客户端的请求都需要指定 DNS 递归解析服务器进行代

理查询处理,因此 DNS 递归解析服务器一直是攻击者执行安全攻击的重要目标. 部署在 DNS 递归解析服务器上的安全机制,既有针对 DNS 流量的也有针对提高 DNS 递归解析服务器系统自身安全性的,总

体来看,部署在 DNS 递归解析服务器上的安全扩展机制主要从完整性和可用性 2 个角度对 DNS 递归解析服务过程提供保护。

3.3.1 完整性

部署在 DNS 递归解析服务器上的数据完整性保护机制主要是从识别响应报文是否合法入手的, DNS 递归解析服务器通过在 DNS 请求流量中加入不容易被离途攻击者猜测的特征信息来识别响应流量是否来自可靠合法的服务器,并提供弱数据源认证保护。本节接下来依次介绍这些 DNS 安全扩展机制。

1) DNS-0x20 encoding

DNS-0x20 encoding 又名随机化大小写技术。DNS 系统具有 DNS 解析的域名名称,不区分大小写,且 DNS 递归解析服务器针对所有查询的应答报文都从启动器的数据包中完全复制域名的具体内容到响应中的特点。DNS-0x20 encoding 利用这一特点,使用加密算法修改原始查询报文中域名字符串的大小写,递归解析服务器端可以通过判断应答报文中问题部分域名信息的大小写情况与原始请求报文的一致性,来判断收到的应答包是否可靠。因此,部署了 DNS-0x20 encoding 的 DNS 递归解析服务器可以依靠过滤域名大小写不匹配应答包,防御递归解析服务器缓存污染攻击^[80]。该机制并未得到广泛部署,在公共 DNS 递归服务器中仅 Google 一家公司支持,但部分 DNS 服务软件允许用户个性化添加 DNS-0x20 encoding。

2) TXID 和源端口号随机化

随机化主要指的是 TXID 和端口的随机化。源端口和 TXID 固定的情况下,攻击者很容易根据已知端口号和 TXID 伪造恶意的应答报文,完成缓存污染攻击。RFC5452^[81]论证了设置 TXID 和端口随机化可以有效避免缓存污染攻击,该标准还指导了实施细节。首先应该使用全范围的随机数,即随机数范围应越大越好;其次,应该使用可靠的强随机函数,避免攻击者在观察了一系列报文后预测出下一报文 ID 和源端口号。

3.3.2 可用性

减少攻击面、识别异常流量和平衡负载等方式可以提高 DNS 递归解析服务器的可用性,尽可能维持 DNS 递归解析服务器为客户端用户持续提供可靠安全的服务。这些安全举措主要从提高 DNS 递归解析服务器面对安全攻击时候的弹性入手,对 DNS 递归解析服务安全提供保护。本节接下来依次介绍这些 DNS 安全扩展机制。

1) DNS 递归解析服务器池

DNS 递归解析服务器池是 NIST 发布的《DNS 服务器最佳实践指南》^[82]中提出的一种可以有效提高 DNS 递归解析系统安全性的系统架构。在该架构中,客户端只能向指定的转发器发送查询请求,然后由转发器将请求转发给可以面向权威服务器执行查询操作的递归解析服务器。在该架构中,由于 DNS 递归解析服务器配置了严格的访问控制,它只接收池内转发器的查询,而不响应池外非法用户的查询请求。

2) 规则匹配

根据 RFC5452^[81]的建议,使用 6 个规则匹配可以有效防护伪造答案的攻击:

- ① 应答源地址与查询目的地址一致;
- ② 应答目的地址与查询源地址一致;
- ③ 应答目的端口与查询源端口一致;
- ④ 请求与应答报文 TXID 一致;
- ⑤ 请求与应答报文 QNAME 一致;
- ⑥ 请求与应答报文 QTYPE 一致。

配置良好的 DNS 递归解析服务器应该对不满足上述规则匹配的应答包予以丢弃,因此可以通过控制权威端发送存在规则不匹配的应答报文来判断 DNS 递归解析服务器是否配置良好,具有规则匹配检测机制。

3) 版本隐藏

DNS 递归解析服务器通常依赖安装专业 DNS 软件来执行 DNS 递归查询功能。但 DNS 软件普遍存在系统漏洞,若版本信息未隐藏,攻击者可以通过版本指纹探测软件扫描远端 DNS 服务器获得具体版本信息,并根据版本选择易于利用的漏洞进行攻击,从而获得 DNS 递归解析服务器的访问权。隐藏 DNS 软件版本可以使攻击者无法获得 DNS 服务器的具体系统漏洞信息,避免攻击者根据 DNS 服务器的版本特征设计攻击利用方案。

4) 软件更新与维护

DNS 服务软件提供商会针对新报道的安全漏洞对 DNS 服务软件进行更新升级,并针对用户反馈等对软件运行维护。使用新版本的软件可以有效防范服务器遭受已知漏洞的攻击,提高服务器的安全可用性。

3.4 作用于通信端口

少量 DNS 递归解析服务安全扩展机制作用于服务器与通信信道连接的端口上,此类安全扩展机制通常是为了防止 DNS 泛洪攻击等对 DNS 服务器造成恶意资源消耗而设计的,因此它们的主要作用是识别数据流是否来自可信任的设备或对数据流进行

筛选限流。

3.4.1 完整性：源地址认证

在端口上对数据源进行认证以保障数据来自受信任的设备可以有效筛选过滤离途攻击者通过陌生网段发送的可疑流量,缓解包括缓存污染、反射放大攻击等在内的多种 DNS 攻击。

RFC2827^[83] 针对基于 IP 源地址欺骗的拒绝服务攻击,提出一个简单、有效且直接的防御方法——启用源地址认证(source address validation, SAV)。RFC3704^[84] 中阐述了 SAV 的具体实现,包括静态控制列表、反向路径转发等。入站源地址认证(inbound source address validation, iSAV),又叫入口流量过滤,iSAV 在入口链路上限制仅允许具有特定前缀内源地址的报文被成功转发,其他的数据报文均被丢弃。与 iSAV 相对应的是出站源地址认证(outbound source address validation, oSAV)。

3.4.2 可用性：响应速率限制

DNS 系统在面对异常大流量请求时,需对流速加以限制以避免影响正常合法用户的使用体验。限流机制既可以增强客户端的系统可用性又可以对攻击者发起的拒绝服务攻击起到较好的防御作用。DNS 响应速率限制是一种在权威端服务器中应用广泛的缓解 DNS 泛洪攻击的措施。健康正常的 DNS 递归解析服务器具有缓存,在缓存记录生存时间内,递归解析服务器会直接使用缓存中的内容进行响应,而非频繁地向权威端请求域名的解析结果。基于此,在权威端设置 DNS 响应速率限制策略,即针对单位时间内响应数量、报错响应数量等进行限制,缓解攻击者利用配置不当的 DNS 递归解析服务器向自身发起泛洪攻击。该方法还能通过阻断权威端的响应,保护下游的受害者客户端^[85]。部分 DNS 服务器还会把大量发送这类异常请求报文的客户端加入黑名单以进一步提高服务器缓解泛洪攻击的能力^[86]。

4 DNS 递归解析服务安全风险评估与测量

DNS 安全扩展机制不仅作用在 DNS 递归解析服务的各个阶段,而且对 DNS 递归解析服务从信息安全 3 要素,即机密性、完整性和可用性这 3 角度均提供了有效防护。但是,任一种 DNS 安全扩展机制都是从 DNS 递归解析服务存在的某一种漏洞弱点出发提供安全保护,不存在可以对 DNS 递归解析服务的全部安全风险提供保护的全能型安全机制。因此,只有配合使用多种 DNS 安全扩展机制才能全面防护

DNS 递归解析服务全流程。相应地,对 DNS 递归解析服务进行安全风险评估也应该纳入多种安全扩展机制进行综合考量。

4.1 DNS 递归解析服务安全评估

一方面,DNS 安全漏洞会被攻击者利用来发起多种攻击;另一方面,在 DNS 递归解析服务器上部署针对安全漏洞的 DNS 安全扩展机制可以有效缓解甚至避免攻击对 DNS 递归解析服务正常运行带来的影响。因此,评估 DNS 递归解析服务的安全性可以从测量 DNS 安全扩展机制的部署情况入手,评估 DNS 递归解析服务系统面对安全攻击的弹性与防御力。

本节主要考虑攻击者是以普通用户身份进行主动攻击的情况,攻击者以用户身份向 DNS 递归服务器发送 DNS 查询请求,并能够注册用于攻击行为的子域名以及构建受控的权威服务器。攻击者具有足够资源实施已披露的攻击,但不考虑攻击者尚未发起的新型攻击。而且,DNS 递归服务链路具有正确配置提及的各项 DNS 安全扩展机制的能力并且不考虑 DNS 递归服务链路中各服务器使用的操作系统、硬件自身漏洞等带来的额外安全风险。

本节首先在表 6 中详细归纳了安全攻击和漏洞与防护手段的关系,然后将针对 DNS 递归解析服务的 5 类安全风险,从安全防护机制出发总结讨论相应的风险评估方法。

4.1.1 缓存污染攻击风险评估

缓存污染攻击成功实施的前提是 DNS 递归解析服务器对响应流量缺乏身份认证与数据完整性保护机制,且基于 DNS 流量默认以明文方式传输的特点,攻击者很容易伪造出足以以假乱真的恶意流量。因此,从完整性和机密性 2 个角度入手,可大大提升 DNS 递归解析服务器防御缓存污染攻击的能力。而从可用性的角度,过滤掉伪造拙劣的数据包,也可以在一定程度上起到针对 DNS 缓存污染攻击的缓解作用。测量 DNS 递归解析服务在这几个方面相关安全机制的部署情况即可评估 DNS 递归解析服务对缓存污染攻击的防御能力。

1) 从数据机密性角度进行评估

对 DNS 递归解析服务器端和 DNS 权威端服务器间的 DNS 流量进行加密可以有效避免攻击者理解通信流量包含的具体信息,以及伪造可以通过服务器私钥解密的 DNS 流量。因此检查 DNS 递归解析服务器端是否支持相关加密机制,即可评估 DNS 递归解析服务是否具有阻断缓存污染攻击的能力。

DNSCurve^[87] 是一种对 DNS 递归解析服务器和

Table 6 Relationship Between the Security Mechanism and the Security Attack of the DNS Recursive Resolution Service

表 6 安全机制与 DNS 递归解析服务安全攻击的关系

DNS 安全扩展机制		攻击类型									
		缓存污染		DNS 劫持		直接破坏 DNS 递归解析服务器		利用 DNS 递归解析服务器攻击其他服务器			软件漏洞利用
		①	②	①	②	④	⑤	④	⑤	⑥	③
机密性	DoT	○	●	○	●	○	○	○	○	○	○
	DoH	○	●	○	●	○	○	○	○	○	○
	DoQ	○	●	○	●	○	○	○	○	○	○
	DNSCurve	○	●	○	●	○	○	○	○	○	○
	DNSCrypt	○	○	○	●	○	○	○	○	●	○
	QNAME 最小化	○	●	○	○	○	○	○	○	○	○
完整性	DNS cookie	●	○	○	○	○	○	○	●	●	○
	DNSSEC	●	○	●	○	○	●	○	●	○	○
	源地址认证	○	○	●	○	●	●	●	●	●	○
	DNS-0x20 encoding	●	○	○	○	○	○	○	○	○	○
	TXID 与源端口随机化	●	○	○	○	○	○	○	○	○	○
可用性	DNS 响应速率限制	○	○	○	○	○	○	○	●	○	○
	DNS 递归解析服务池	○	○	○	○	●	○	○	○	○	○
	规则匹配	●	○	●	○	○	○	○	○	○	○
	版本隐藏	○	○	○	○	○	○	○	○	○	●
	软件维护与升级	○	○	○	○	○	○	○	○	○	●

注：①缺乏身份认证机制/完整性保护；②数据明文传输；③软件系统存在安全漏洞；④缺乏流量访问控制；⑤对异常流量缺乏鉴别能力；⑥具有被利用为放大器的潜力。“○”表示几乎不具备防御能力；“●”表示可以作为主要的防御缓解措施且存在一定的辅助性缓解作用。

DNS 权威端服务器间的 DNS 流量提供机密性保护的 DNS 安全扩展机制,它使用的椭圆曲线算法强度经 NIST 认证与 3 072 位的 RSA 算法类似,攻击者在未知加密双方私钥的情况下成功破解需要 10 年以上的时间^[88].而且支持 DNSCurve 的递归解析服务器与权威服务器之间,一经密钥交换后续可选仅接收经过加密的安全数据报文而丢弃伪造的明文数据^[89].因此,在 DNS 递归解析服务器—权威端服务器通信链路上部署 DNSCurve 这一 DNS 安全扩展机制,可有效阻断缓存污染攻击,攻击者在私钥未泄露的情况下攻击成功的概率接近于 0.

QNAME 最小化技术从尽可能减少信息暴露和保护用户隐私不被非法记录的角度缓解缓存污染攻击^[90].QNAME 最小化技术让权威端服务器只能获取尽可能少的用户信息,保护用户隐私安全,使权威端请求流量中请求名称一直处于变化当中,增加攻击者成功猜测合法报文的难度^[91].

如果未来在 DNS 递归解析服务器—权威端部署了 DoT, DoH, DoQ, 缓存污染问题也会因为传输链路上数据被加密而得到妥善解决.

2) 从数据源认证与完整性角度进行评估

对 DNS 流量进行数据源认证保护、数据完整性保护也可以有效阻断缓存污染攻击,因为缓存污染攻击通常由离途攻击者依靠“猜测”构造可被 DNS 递归解析服务器识别接收的响应流量实施,而数据源认证与完整性保护可以使“猜测正确”的概率无限趋近于 0.基于此,测量远端 DNS 服务器对这类安全机制的部署情况可以刻画 DNS 递归解析服务针对缓存污染攻击的完整性保护情况.

使用密码学工具是较为常用且有效的提供数据源认证与完整性保护的方式.在针对 DNS 流量的保护上,一次性令牌和加密数字签名是 2 种行之有效的数据源认证方案,其中加密数字签名在实现源认证的基础上还能提供数据完整性保护.

DNS cookie 作为一种轻量级的一次性明文令牌认证协议,通信双方通过协商使用频繁更换的 cookie 值作为身份认证令牌.DNS cookie 使用的客户端令牌和服务端令牌均为不小于 64 位的随机数组成,且服务端给不同客户端 IP 提供不同令牌的保证可以有效防御平行会话攻击^[66],这使得攻击者需要进行最坏 17 179 PB 次尝试才能伪造出正确的 64 位 cookie.可以认为,对于离途攻击者来说,难以将伪造响应注

入使用 DNS cookie 的递归服务器中^[66]。但是由于 DNS cookie 使用明文传输令牌, 它对于在途攻击者发起的缓存污染攻击无法提供保护。

区别于 DNS cookie 使用明文传输令牌, DNSSEC 使用密码学工具构造以根服务器为信任根的信任链。DNSSEC 支持多种不同的密码算法, 即便使用其中最简单的 RSA/SHA1, 现代计算机也需要至少 1~2 h 才能碰撞破解^[87], 因此在有效时间窗口下, 攻击者难以伪造出能被接受的错误响应。域名解析结果均从根区开始进行数字签名, 以保护解析结果的完整性和数据源的可信度。递归解析服务器通过验证签名和判断信任链是否完整来判断解析结果是否真实可信, 使攻击者无法伪造出能通过 DNSSEC 认证的响应报文来阻断缓存污染攻击^[92]。

往 DNS 数据中添加一次性随机变量, 包括随机数、字符随机排列等, 可以防御由离途攻击者发起的针对 DNS 递归解析服务器的缓存投毒攻击。它是基于非路径攻击者未知请求报文中的随机变量且无法在短时间内构造出包含正确随机变量的伪造响应这一事实, 对 DNS 递归解析服务器提供保护。

使用 TXID 和源端口号随机化, 可以抵御缓存污染攻击。TXID 和源端口号随机化利用 DNS 递归解析服务器滑动窗口机制仅能处理较短时间内的有限响应流量的特点^[93], 降低攻击者在有限空间内猜测出正确的 TXID 和源端口号组合的概率, 达到避免伪造流量被 DNS 递归解析服务器接收并缓存的目的^[94]。但是 TXID 和源端口号随机化的实际防御能力受随机端口号生成算法的强弱和随机数范围的限制, 即只有在随机数范围较大(最好是全 ID 段和全可用端口区间)且使用不容易被攻击者猜测出下一可能随机数的强随机数算法时, 随机化方法对于 DNS 缓存污染攻击的防御效果才能达到最大。在最好的情况下 TXID 随机范围为 [0, 65 535], 源端口号随机范围为 (1 024, 65 535], 带入 RFC5452^[81] 中的时间窗口、TTL 等参考参数值进行计算, 该随机空间下的攻击流量至少 285 GBps, 因此 TXID 和源端口号随机化在一般攻击条件下具有较好的防御效果。

与 TXID 和源端口号随机化直接引入随机数不同, DNS-0x20 encoding 使用随机算法随机修改域名字符串的大小写排列, 并向 DNS 流量引入随机变量。DNS-0x20 encoding 的防御效果与域名自身长度息息相关, 据统计, 几乎全部正常域名的字符长度在 19 以内, 大部分正常域名的字符长度集中在 8~12^[95]。对于攻击者来说, 使用 DNS-0x20 encoding 后的域名字

符串随机区间最大在 105 万以内, 大部分情况下在万以内。因此, 若 DNS 递归解析服务器仅接收使用 DNS-0x20 encoding 的响应流量, 就可以有效缓解 DNS 缓存污染的影响^[94]。

这些安全机制均对抵御缓存污染攻击具有帮助, 但是各机制也有其不足之处, 如 DNS cookie 仅能提供弱认证, DNSSEC 信任链的完整性非常依赖 DNS 权威端的广泛部署, TXID 和源端口随机化的随机区间与随机算法的选择会直接影响防御能力而 DNS-0x20 encoding 算法在域名长度非常短时防御效果不理想等。因此, 评估 DNS 递归解析服务面对缓存污染攻击的完整性时, 可以从探测远端服务器针对这几种安全扩展机制的组合部署情况入手, 加权评估整体的完整性防御水平。

3) 从数据可用性角度进行评估

攻击者发出的虚假响应通常存在与用户的原始请求信息不一致和不完全匹配的情况, 因此评估 DNS 递归解析服务器是否对请求-响应进行规则匹配, 则可以判断 DNS 递归解析服务器在面对伪造答案时的弹性。

4.1.2 DNS 劫持安全风险评估

DNS 劫持攻击者拦截并篡改 DNS 服务流量, 把客户端重定向到攻击者自身的服务器或网站去。DNS 劫持与缓存污染攻击实现攻击的手段具有相似之处, 即均通过篡改 DNS 流量中的数据, 给受害客户端提供错误响应, 只不过 DNS 劫持在信道上进行流量拦截篡改而缓存污染攻击向 DNS 递归解析服务器缓存直接注入错误数据。因此, 这 2 种攻击的防御能力评估方法具有相似之处, 即评估服务器是否具有对流量来源进行数据源认证与对流量数据本身进行完整性保护的能力, 或是否具备保障数据机密性使 DNS 流量不易被篡改的条件。

1) 从数据机密性角度进行评估

对 DNS 流量进行加密可以有效防御在途攻击者发起的 DNS 劫持攻击, 因为加密后的 DNS 流量所包含的信息对于没有解密密钥的攻击者来说是难以被理解的, 而且即使能够被理解, 攻击者在不具备加密密钥的情况下也难以正确加密伪造数据, 若 DNS 递归解析服务支持这类安全机制则说明 DNS 递归解析系统具有从机密性角度防御 DNS 劫持攻击的能力。

对于客户端与 DNS 递归解析服务器端间的 DNS 流量数据保护来说, 利用 DNSCrypt 直接加密或使用 DoT, DoH, DoQ 这 3 种加密传输协议来加密传输 DNS 流量也可以有效保护 DNS 流量免受 DNS 劫持攻击的

影响.DNSCrypt 脱胎于DNSCurve,具有不低于DNSCurve的安全性,且提供多种可选的加密方案对DNS请求与响应流量进行加密,使攻击者即使截获了DNS通信报文也无法理解或篡改它,保障通信双方接收到的DNS流量数据内容真实可信;与DNSCrypt通过提前协商使用的加密算法、交换公钥不同,DoT, DoH, DoQ直接使用已有的加密传输协议加密DNS数据流量,使用已有的传输协议封装DNS数据还可以让DNS混杂在大量其他加密数据流中,增加DNS流量的隐蔽性^[96-97].这3种DNS加密传输协议的安全性与各自依托的具体传输协议,即TLS, HTTPS, QUIC相关,而TLS, HTTPS, QUIC均被视为使用广泛且安全性较高的加密传输协议,因此在使用DoT, DoH, DoQ时可以保证DNS数据在面对DNS劫持时的安全性.

对于DNS递归解析服务器端与权威端服务器端间的DNS流量数据保护来说,DNSCurve是一种针对DNS劫持具有较好防御效果的DNS安全扩展机制.在DNSCurve算法的保护下,理论上破解加密密文内容需要上百年,因此使用DNSCurve加密DNS递归解析服务器与权威端间的通信流量可以有效避免网络中间转发设备对DNS响应流量的隐私窥探和内容篡改,保证DNS递归解析服务器接收到的响应流量内容真实可信.因此可分别探测DNS递归解析服务在这2段信道上的防御水平,评估DNS递归解析系统面对DNS劫持攻击时的防御能力.

2) 从数据完整性角度进行评估

DNS劫持攻击的原理是在通信信道上拦截并篡改DNS流量,因此对DNS流量进行源地址认证和数据完整性保护,使篡改后的流量不能通过接收方的验证有效阻断DNS劫持攻击.下面介绍几种常见的防御手段,通过评估DNS递归解析服务是否部署了这些防御手段即可评估递归解析系统面对DNS劫持攻击时的完整性防御水平.

密码学工具是最常见的有效进行数据源认证和保护数据完整性的工具,DNSSEC则是此类安全防御机制的典型代表.在信任链完整的情况下,配置了DNSSEC的DNS递归解析服务器使用数字签名和公钥验证NS记录来判断DNS流量是否被中间人篡改以及数据报文是否来自正确的权威服务器^[98],使DNS劫持攻击者即使成功拦截了DNS流量数据也无法使恶意改动后的数据被DNS递归解析服务器接收,避免客户端被DNS劫持到错误的服务器或网站.DNSSEC在DNS劫持中的安全表现与在缓存污染攻击中的表现类似,在正常配置DNSSEC的情况下可正常保障

DNS递归解析系统在递归解析服务器—权威端面对DNS劫持攻击的安全性.

除去密码学工具,源地址认证也可以有效阻断DNS劫持攻击者的攻击.源地址认证等手段对出入口流量进行过滤,识别并丢弃潜在的劫持流量以防御DNS劫持攻击.被攻击者劫持后的DNS流量具有IP地址陌生以及AS域与预期不一致等问题,在客户端设置响应流量入口过滤可以过滤大量攻击者发送的不可信解析结果.在正确完善配置源地址认证的情况下,攻击者只有在特定IP域内实施DNS劫持攻击才有可能绕过源地址入端口过滤,苛刻的攻击环境能够有效缓解客户端由于DNS流量被劫持而被重定向至恶意网站的问题^[83].

最后,还可以通过TLS证书等信息标识,识别权威端服务器的信息变化,侧面判断权威服务器是否被接管从而判断DNS劫持攻击是否发生^[99].攻击者在攻击权威端服务器时,由于需要短暂地入侵接管权威端服务器,权威端的TLS证书、AS域等信息会短暂地发生变化,客户端可以监测权威端服务器一段时间内TLS证书信息的变化来判断对方服务器是否被劫持攻击,过滤不信任的流量以缓解权威端DNS劫持对客户端的影响.

3) 从数据可用性角度进行评估

DNS流量信息泄露会导致用户敏感数据被非法获取与使用;而DNS系统如果不能识别和处理明显异常的数据流量,则会导致用户从DNS系统中接收到错误的信息,从而影响正常的DNS递归解析服务过程,破坏DNS系统的有效性.因此,考察DNS递归解析服务是否部署了相关安全机制即可判断它是否具有削弱DNS劫持攻击带来的安全风险的能力.

使用配置良好的DNS服务器能检查并丢弃不符合规则匹配原则的DNS数据包,在一定程度上缓解DNS劫持攻击造成的影响.在DNS攻击中,攻击者篡改接获的流量,把用户重定向至攻击者指定的服务器或域名网站,但篡改后的数据报文普遍存在源端口号不一致和IP不一致等错误.因此,配置良好的DNS递归解析服务器在对接收到的请求与对应的响应报文进行规则匹配的过程中,可以筛选出具有潜在危害的异常报文,缓解DNS劫持攻击.

4.1.3 直接破坏DNS递归解析服务器安全风险评估

针对各具体攻击类型的防御方法如表7所示,评估DNS递归解析服务器防御这些安全攻击能力时也可以从探测表7中安全扩展机制的部署情况入手,以部署的安全扩展机制的防御范围能全面覆盖这些

Table 7 Defenses Against Three Common Types of Attacks
表 7 3 类常见攻击的防御手段

DNS 安全扩展机制	NXDOMAIN 攻击	幻域攻击	泛洪攻击
DNSSEC cache-validation	√	√	×
NXDOMAIN cut	√	√	×
源地址认证	√	√	√
递归解析服务器池	×	×	√

注：“√”表示 DNS 安全扩展机制可以缓解该攻击；“×”表示 DNS 安全扩展机制不能缓解该攻击。

攻击类型为宜。

DNSSEC cache-validation 如 3.2 节中的描述,通常用来证明一个区域内域名的不存在性^[100]。DNSSEC cache-validation 这一防御手段,虽然利用了完整性保护机制 DNSSEC,但是主要对 DNS 拒绝服务攻击起到防御作用的,还是它可以用一条否认记录否认整个区间段的域名存在性的特点。由于 NXDOMAIN 攻击和幻域攻击主要利用 DNS 递归解析服务器需要对每一个没有缓存的域名进行递归查询的弱点发起攻击,因此使用 DNSSEC cache-validation 机制运用“以点带面”的原理,一次性证明一类随机域名的不存在性,大幅度降低 DNS 递归解析服务器执行查询的频率,缓解攻击对 DNS 递归解析服务器缓冲区等资源的占用问题。而且,因为 DNSSEC cache-validation 内对某一个域名段的否认是经过 DNSSEC 签名的,所以这一条否认记录得到了妥善的完整性保护,攻击者很难通过伪造错误的 DNSSEC cache-validation 记录削弱防御能力,给 NXDOMAIN 攻击和幻域攻击重新创造有利条件。

NXDOMAIN cut^[36] 利用恶意域名通常具有相同后缀的特点,当递归解析服务器接收到针对不存在恶意后缀的 NXDOMAIN cut 消息时,对于具有此类后缀的全部恶意请求均直接返回 NXDOMAIN 消息,缓解攻击者恶意构造大量不存在域名解析请求占用 DNS 递归解析服务器有限缓存与计算资源的问题。

入口源地址认证因为可以对流量源地址以网段或 IP 进行认证筛选,对于缓解利用泛洪手段直接破坏 DNS 递归解析服务器功能的攻击卓有成效。关闭开放的 DNS 递归解析服务器,使 DNS 递归解析服务器只能服务于指定网段内的主机或客户端,可过滤全部来自未知网段的客户端发起的恶意查询流量,缓解针对 DNS 递归解析服务器的泛洪攻击^[101]。

DNS 递归解析服务器池则是从负载均衡的角度对 DNS 递归解析服务器提供保护。DNS 递归解析服务器池由大量转发器、缓存和少量真实执行面向权

威端服务器的迭代查询的 DNS 服务器组成。在这个结构中,由多个受控主机发送的众多 DNS 查询请求会分别由多个 DNS 转发器子结构处理,且这些子结构共用同一个缓存,大大降低了每个子结构的流量压力以及查询服务器的查询压力,削弱异常流量带来的影响。

4.1.4 利用 DNS 递归解析服务器攻击其他服务器的安全风险评估

针对客户端与递归解析服务器端和递归解析服务器端与权威服务器端间的攻击,管理者既可以利用二者之间的共性弱点设计通用的防御方式,也可以针对各自攻击模型的独特性设计防御“特效药”,这些安全机制分别从机密性、完整性和可用性 3 个角度入手展开防御。2 类攻击信道端的主要防御机制如表 8 所示,这些安全机制的有效部署可以大幅降低 DNS 递归解析服务器的可利用性,保证 DNS 递归解析服务系统的安全稳定运行。

Table 8 Comparison of Defenses Against Attacks in Different Channels

表 8 不同信道下攻击的防御手段比较

攻击信道	不同部署位置下存在的防御机制	通用防御机制
客户端与递归解析服务器端	DNSCrypt	源地址认证
	DNS cookie	
递归解析服务器端与权威服务器端	DNSSEC cache-validation 响应速率限制	

1) 仅针对客户端与递归解析服务器端间信道

DNSCrypt 和 DNS cookie 主要对发生在客户端与递归解析服务器端间通信信道上的攻击提供保护,但是在此类攻击中,这 2 种安全机制不再分别提供机密性和完整性方面的保护,它们主要是通过消除放大潜力和对大量重复的异常流量提供流量控制来提供安全性保护,探测这 2 种安全机制的部署情况即可评估 DNS 递归解析服务器的反射放大利用潜力。

使用 DNSCrypt 机制可以针对性地缓解客户端与递归解析服务器端间的反射放大攻击^[102]。反射放大攻击的原理为利用 DNS 响应流量普遍数倍到数十倍请求流量的特点,以 DNS 递归解析服务器为放大器,把攻击者伪造的大量请求流量放大后反射到客户端,形成对客户端的泛洪攻击。DNSCrypt 的使用会对 DNS 请求和响应流量同时进行加密,使攻击者自身计算资源、带宽资源的消耗大幅增加,二者的流量大小差距明显缩小,破坏构成“放大”的条件。

DNS cookie 也是通过缩小放大倍数的方式缓解 DNS 反射放大攻击^[103]. 在强制使用 DNS cookie 的链路中, 若攻击者发送不存在 DNS cookie OPT 的恶意请求, DNS 递归服务器仅会返回带有速率限制的载荷大小在 512 B 以内的错误响应短报文^[66]. 在这种情况下, 响应放大倍数将与传统 DNS 相当.

2) 仅针对递归解析服务器端与权威服务器端间信道

DNSSEC cache-validation 和响应速率限制主要对发生在递归解析服务器端与权威服务器端间的攻击提供保护. 这 2 种机制的部署情况可以反映 DNS 递归解析服务器被利用参与 DDoS 攻击权威端服务器的能力.

DNSSEC cache-validation 可以有效缓解随机子域名攻击对权威端服务器带来的不良影响. 与直接攻击 DNS 递归解析服务器相同, 此处 DNSSEC cache-validation 不再是借助 DNSSEC 直接给数据提供完整性保护, 而是给 DNS 递归解析服务器提供来源可靠的地址段否认记录, 达到针对大量不存在子域提供否认认证的作用^[47].

响应速率限制通过过滤潜在异常流量防御针对权威端服务器的 DDoS 攻击. 攻击者借助递归解析服务器发送大量相似或重复的查询请求来发起攻击, 因此丢弃短时间内发送过于频繁的查询请求并把短时间内发送大量异常解析请求的 IP 地址加入黑名单, 可以极大地缓解此类攻击, 保障合法递归解析服务正常进行^[86].

3) 可对 2 段通信路径构成保护

源地址认证技术使用 ACL 白名单等手段使 DNS 递归解析服务器仅接收服务区域内或受信任的特定网段主机发送的域名解析请求, 而对其他非法请求直接过滤丢弃, 可以有效减少 DNS 递归解析服务器的攻击面, 对远程攻击和使用僵尸网络受控主机发起的拒绝服务攻击具有良好的缓解作用^[104].

4.1.5 软件漏洞利用安全风险评估

为降低 DNS 系统软件的潜在风险和缓解漏洞利用攻击, DNS 服务软件提供商会针对发现的漏洞, 对受影响的软件版本打补丁并定期更新发布更安全的新版本, 修复软件系统存在的安全问题. 因此, 使用较新版本且仍处于维护状态的 DNS 系统软件版本, 可以最大限度地保障 DNS 服务不被已知漏洞攻击利用, 缩小攻击面^[105].

基于软件版本与漏洞的可利用性具有强关联性的现实情况, 攻击者在攻击入侵前通常会重点探测

目标服务器 DNS 系统软件的详细版本信息, 并以此作为攻击手段确立的重要指标. 部分 DNS 服务软件厂商, 如 BIND, 通过允许用户修改服务器软件版本记录文件的方式, 辅助用户按需隐藏用户 DNS 服务器的版本信息^[106]. 隐藏的 DNS 软件版本信息可以在攻击者系统侦测阶段通过使攻击者难以确定攻击手段的方式缩小攻击面进行防御.

综上所述, 在 DNS 系统中, 评估 DNS 服务软件的更新维护情况以及是否积极隐藏软件版本可以有效评估系统的可用性防御水平.

4.2 安全扩展机制测量

评估某一段 DNS 递归解析服务针对某一类型安全攻击的安全性, 可以从评估各 DNS 安全扩展机制针对各类型攻击的防御水平以及整个 DNS 递归解析服务链路上与该类型安全攻击相关的 DNS 安全扩展机制的部署情况入手, 即一方面, 相关 DNS 安全扩展机制部署越完善, 递归解析服务的攻击防御能力越高. 另一方面部署的 DNS 安全机制可缓解的安全攻击种类越全面以及 DNS 递归解析服务整体上攻击面越小, 安全性越高, 反之亦然.

虽然不同的安全扩展机制的部署测量在实操上互不相同, 各有特色, 但是它们之间依旧存在思想上的相似点, 即 DNS 安全扩展机制的部署会造成 DNS 流量的变化, 而对 DNS 安全扩展机制的远端测量极大地依赖对流量变化的测量与分析.

一般情况下, 测量者会在客户端部署测量点, 但是, 部分 DNS 安全扩展机制仅会影响服务器端—权威端的数据流量, 而这难以在客户端观测, 因此这些 DNS 安全扩展机制需要在权威端部署测量点进行测量. 据此, 如图 11 所示, 本节把 DNS 安全扩展机制的

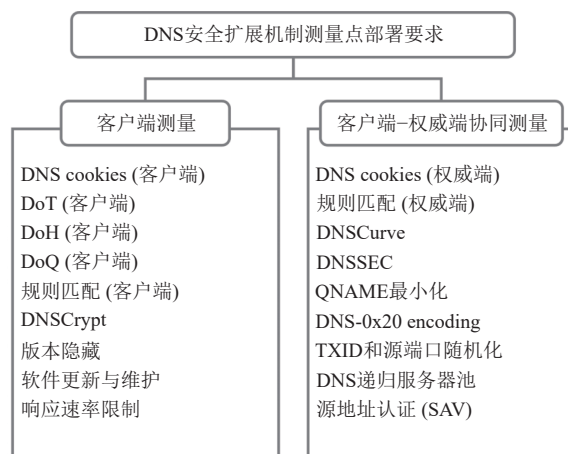


Fig. 11 Security extension mechanisms measurement method

图 11 安全扩展机制测量方法

测量方法, 根据测量点的部署要求分为客户端测量与客户端—权威端协同测量 2 类展开介绍。

4.2.1 客户端测量

部分 DNS 安全扩展机制的部署情况可以在仅客户端部署测量点的条件下准确测量, 这类 DNS 安全扩展机制通常部署在客户端—DNS 递归服务器链路端、DNS 递归服务器端。本节接下来将依次介绍使用这类测量方法的 DNS 安全扩展机制。

1) DNS cookie(客户端)

DNS cookie 主要通过提供轻量级的一次性明文令牌进行弱身份验证保护, 它虽然不对 DNS 数据流量提供机密性保护, 但是在接收到包含单方 DNS cookie 令牌的短消息请求后, 偶尔会返回附加自身 DNS cookie 的 BADCOOKIE 应答, 因此客户端测量者可以通过判断能否收到 BADCOOKIE 响应以及后续通信过程能否持续收到远端 DNS 递归解析服务器的一次性身份验证令牌来判断远端 DNS 递归解析服务器对 DNS cookie 的支持性^[67]。

DNS cookie 得到了部分大型 DNS 软件商的支持, 包括 BIND9, Knot, Unbound 等。但是, DNS cookie 的整体部署情况不佳, Davis 等人^[107]针对 DNS cookie 的部署情况于 2020 年 9 月进行了系统的测量, 仅 30% 的 DNS 服务器和 10% 的 DNS 递归解析服务器中的客户端支持 DNS cookie。

2) DoT, DoH, DoQ(客户端)

DoT, DoH, DoQ 的测量工作具有一定的相似性, 它们均是通过有针对性地改变请求流量的目的端口号再辅以独有的特征来判断远端 DNS 递归解析服务器是否支持 3 种加密传输协议。在具体实施测量时, 首先需要扫描特定端口的开放情况, DoT 与 DoQ 协议针对 853 端口以及 DoH 协议针对 443 端口进行扫描; 之后, 根据协议类型不同、构造不同的测量探针, 针对 DoT 的探测通常试图构造 TLS 会话连接并发送 DoT 请求报文^[108], 针对 DoH 的探测则构造并发送可能的 URL 请求模板^[109], 而针对 DoQ 则发送包含无效版本号 0 的 DoQ 握手消息的请求报文^[110]。

目前有多家 DNS 软件厂商和 DNS 服务器厂商陆续在最新版本的 DNS 产品中宣称支持 DoT 协议, Power DNS 宣称从 1.3.0 版本开始支持 DoT, Google 从 2008.4 开始在 Android9 中使用 DoT, Knot resolver 支持 Linux 和 Windows 双系统的 DoT 加密传输等^[111]。

而 DoH 协议目前也在 Firefox, Google 等大型浏览器中得到广泛部署, 用户可以选择是否使用 DoH 协议来保障自己的隐私信息^[112]。

但是 DoQ 目前还在测试阶段, 并没有得到大范围的全面部署, 截至 2022 年全球仅有百余台 DNS 服务器部署了 DoQ 并开放使用, 其中有 45.19% 处于亚洲、有 32.37% 处于欧洲而有 17.83% 位于北美洲^[110]。

3) 规则匹配(客户端)

远端 DNS 递归解析服务器对规则匹配的检查与执行情况进行测量, 如果 DNS 递归服务器端返回的响应报文中包头信息与请求报文存在不一致, 则远端 DNS 递归服务器没有进行谨慎的客户端规则匹配机制。

4) DNSCrypt

DNSCrypt 提供多种可选的经过证书签名的加密方案及其对应的公钥与客户端协商后续通信的加密方案, 因此可以通过客户端检测递归解析服务器端返回应答是否包含 DNSCrypt 签名证书的方式^[55], 判断对方服务器是否启用了 DNSCrypt 服务。

在包括 OpenDNS, Yandex, AdGuard, Quad6 等公共 DNS 服务器中都广泛部署了 DNSCrypt^[65]。大多数 DNS 服务软件也支持针对 DNSCrypt 的配置, 比如 BIND9, DNSmasq 等使用广泛的专业 DNS 服务软件版本^[111]。

5) 版本隐藏和软件维护与升级

Duan 等人^[14]提供了一种有效的扫描方案, 即利用绝大多数 DNS 服务器使用 BIND 软件的特征, 首先用 bind.version 进行扫描, 判断其是否是 BIND 服务器以及是否公开了版本信息, 针对非 BIND 服务器再用 fpdns 工具加强扫描, 若依旧不能得到版本信息, 则认为远端 DNS 递归解析服务器隐藏了版本信息, 否则记录远端 DNS 递归解析服务器的具体软件版本。使用该测量方法, 可以一次性收集版本隐藏和软件维护与升级 2 个指标的具体数据。

Takano 等人^[113]在 2013 年进行了一次针对全 IPv4 范围的 DNS 服务器服务软件版本扫描, 在该次实验中大约 54% 的 DNS 服务器进行了版本隐藏。

至于未隐藏软件版本的 DNS 服务器, 陆柯羽^[114]在 2015 年测得, 中国江苏省使用 BIND 软件的服务器占全部服务器的 41.25%, 紧随其后的是 Paul Rombouts pdnsd 占全部扫描结果的 28.17%, Mikrotik dsl/cable 占比为 27.92%, 其他服务器软件的使用占比很小^[105]。

6) DNS 响应速率限制

测量者可针对每一个待测量 DNS 服务器在极短时间内发送一组重复查询, 并依次增加同一组内重复查询的数量, 考察远端服务器启动响应限制的具体速率^[115]。现有配置了 DNS 响应速率这一缓解措施

的 DNS 服务器占比较低, Deccio 等人^[116]于 2019 年测得仅有 16% 左右的 DNS 递归解析服务器配置了这一缓解措施。

4.2.2 客户端—权威端协同测量

需要在客户端和权威端同时部署测量点的 DNS 安全扩展机制通常部署在 DNS 递归服务器—权威链路端和 DNS 递归服务器端。这些安全扩展机制产生的特殊流量很难在客户端观测到, 需要通过把流量导向自建 DNS 权威端的测量点才能进行记录分析。本节接下来将依次介绍使用这类测量方法的 DNS 安全扩展机制。

1) DNS cookie(权威端)

如果远端 DNS 递归服务器部署了针对权威端的 DNS cookie, 位于权威端的测量者可以在 DNS 递归服务器发送的请求流量的 OPT 中获得远端 DNS 递归服务器的 client cookie, 反之亦然^[66]。

2) 规则匹配(权威端)

远端 DNS 递归解析服务器对规则匹配的检查与执行情况进行测量, 可以使用权威端发送存在规则不匹配的应答报文, 如果远端 DNS 递归解析服务器可以把不满足规则匹配的应答包予以丢弃, 则远端 DNS 递归解析服务器进行了规则匹配^[81]。

3) DNSCurve

使用 DNSCurve 的 DNS 递归解析服务器在从使用 DNSCurve 的权威端服务器流量中识别到权威端服务器的 DNSCurve 公钥后会返回自身 DNSCurve 公钥完成密钥交换, 因此测量者须使用支持 DNSCurve 的权威服务器向 DNS 递归解析服务器发送包含公钥的 NS 记录, 测量者再根据权威端是否能接收到来自递归解析服务器发送的包含自身公钥、随机数和加密盒的数据包判断待测 DNS 递归解析服务器是否支持 DNSCurve^[70]。

DNSCurve 的部署情况不容乐观, 目前只有 OpenDNS 这一个大型公共 DNS 服务器宣称支持这一协议。

4) DNSSEC

DNSSEC 的测量则主要聚焦于设计针对 OK 位的特殊探针, 远端测量者利用 DNSSEC 的启用从客户端向递归解析服务器端发送包含 DNSSEC OK 的 EDNS0 查询开始的特点, 构造包含 DNSSEC OK 位且查询支持 DNSSEC 的域名(如查询 paypal.com)的解析请求, 根据 DNSSEC 相关资源记录的接收情况判断远端 DNS 递归解析服务器是否具备解析 DNSSEC 的功能^[76]。通常, 为了确保测量的准确性, 可以在权威端精心构造存在错误的响应信息, 进一步判断 DNS 递归服务器是否存在配置错误以及是否正确验

证了 DNSSEC 签名^[78]。

在 DNSSEC 分布上, 存在部分顶级域名中 DNSSEC 大量集中部署而其他顶级域名下几乎没有部署的特点, 在相对集中的顶级域内, 2 级域的 DNSSEC 部署可达 50%; 在 NSEC 版本的选择中, 79% 的域选择了更安全的 NSEC3; 在算法选择上, 2 级域主要选择 RSA 算法^[117], 且有不在少数的域选择了不安全的 512 位 RSA 算法^[118]。

5) QNAME 最小化

QNAME 最小化的测量依靠 RIPE Atlas 探针进行, 测量者发送包含受控 DNS 权威服务器信息的探测报文, 若受控权威端能接收到全部的查询信息则会返回包含“最小化未支持”的 TXT 信息, 否则返回“支持最小化”的 TXT 信息^[119]。

QNAME 最小化自标准化以来, 得到了广泛的部署与支持。多家 DNS 服务软件提供商支持 QNAME 最小化配置, 包括 BIND 从 9.13.2 版本开始支持 QNAME 最小化以及 Unbound 在 1.5.7 中第 1 次支持 QNAME 最小化且 Knot 在 1.1.0 版本中也提供了对这一机制的支持^[120]。

6) DNS-0x20 encoding

使用 DNS-0x20 encoding 的服务器, 由于会对每一份报文使用随机化算法修改原始查询报文中域名字符串的大小写, 因此若远端 DNS 递归解析服务器支持 DNS-0x20 encoding, 则权威端收到的请求报文中的域名大小写是随机变化的, 反之域名内容全部由最原始的小写字符构成^[121]。

DNS-0x20 encoding 得益于它的强兼容性和有效性, 一经提出就得到业内关注。在 Google 公司的大型公共递归 8.8.8.8 中, DNS-0x20 encoding 得到了推广应用, Google 公司宣称在它的公共 DNS 流量中有 70% 的流向支持 DNS-0x20 encoding 的服务器^[122]。此外, 很多知名 DNS 服务软件, 如 Unbound^[123], Knot^[124]等, 也支持用户自主选择配置 DNS-0x20 encoding 安全机制。

7) TXID 和源端口随机化

对于部署了 TXID 和源端口随机化的服务器或主机, 连续捕获收集一段时间内的数据流量, 从代数与统计学的角度出发, 使用 NIST^[125], 基于统计学原理开发的统计检测套件^[126]、基于统计距离和迭代对数定律的测试技术或与随机性检测相关的经典算法, 如 Wald-Wolfowitz 运行测试^[127]、频谱测试^[128]和卡方检验^[129]等评估随机数序列的可预测性与随机数的分布情况等, 即可测量出远端 DNS 递归解析服务器对 TXID 和源端口随机化的部署情况。

在 Kaminsky 攻击成功之前, DNS 流量的 TXID 与源端口随机化尚未得到学界的重视, 几乎没有 DNS 递归解析服务器进行随机化设置. 在此之后, TXID 与源端口号随机化得到大力推广与部署, 截至 2021 年仅有 0.75% 的递归解析服务器完全没有配置任何端口范围大小的随机源端口和 0.33% 的递归解析服务器使用完全固定的 TXID^[120].

8) 递归解析服务器池

设置可触发链式反应、循环发送的探针, 即利用 CNAME 构造递归解析服务器池与权威端之间的查询-响应循环, 并记录权威端接受到的 IP 数据集, 判断面向客户端的 IP 与面向权威端的 IP 的映射关系, 刻画出递归解析服务器池结构^[15].

9) 源地址认证(SAV)

在源地址认证的测量工作中, 向区域内所有服务器发送带有欺骗源地址的请求包, 观察权威端能否收到递归查询请求, 若可以则说明未进行 iSAV 过滤^[130]; 而针对 oSAV 部署的主动测量, 测量者可利用行为不端的解析器, 检查 oSAV 的部署情况^[131]; 测量者还可以使用跟踪路由数据中出现的路由环路来判断是否设置了 oSAV 过滤, 未设置者存在不会过滤非法用户流量的特征^[132].

Korczyński 等人^[133]总结了进行源地址认证可以有效防御缓解诸如反射放大攻击、NXDOMAIN 攻击等恶意攻击, 且 55% 的 IPv4 AS 域部署了 iSAV^[134]. Spoofer Project 发现 2015 年至今已有 7 915 个 IPv4 AS 域部署了 oSAV.

5 研究方向与展望

本文系统总结了 DNS 递归解析服务的攻击防御机制, 包括其针对递归解析服务面临安全风险的保护原理、效果和测量评估方法. 尽管 DNS 安全防护技术在不断发展, 递归解析服务仍面临着险峻的安全风险, 未来针对递归解析服务的安全攻击将更加精准和隐蔽, 现有安全防护机制仍不能很好地满足针对大规模递归解析服务安全风险的监测、评估与治理的重要需求, 通过对现有方法的总结分析, 未来的研究工作可以关注以下 4 个方面.

5.1 大规模递归解析服务器的可扩展监测

递归解析服务器发现是递归解析服务安全风险监测的基础, 然而递归解析服务器规模庞大、动态易变且层次依赖关系复杂, 目前的递归解析服务器发现方法主要依赖主动探测手段, 其仅能够发现开放

的递归解析服务器, 并且对递归解析服务器所属层次和类型的分析研究尚不完善. 因此未来可进一步研究主动探测与被动日志分析相结合的递归解析服务器发现方法, 从创新递归解析服务器的快速分层分类方法出发, 研究大规模递归解析服务器的高效发现和可扩展监测. 同时, 需要研究设计全面科学的递归解析服务分析评级模型, 对探测发现的递归解析服务器进行精准分级和质量评估, 有助于实现对递归解析服务的全面持续和精细化监测.

5.2 递归解析服务器多维度风险建模与安全评估

虽然目前已有许多研究工作从多维度分析总结了递归解析服务面临的安全风险, 但现有工作主要关注递归解析服务单个风险点的研究, 无法系统地刻画和评估递归解析服务安全风险. 本文从 5 个安全风险维度出发, 对递归解析服务安全风险与防护机制进行了系统性分析, 并从防护机制入手对递归解析服务安全风险评估与测量方法展开综述. 未来可在此基础上研究构建递归解析服务安全风险评估模型, 设计多维安全风险评估指标体系, 通过测量多种类别风险指标实现相关安全风险的准确发现与监测预警.

5.3 递归解析数据驱动的大规模网络攻击发现

当前国内外 DNS 递归解析服务攻击形势复杂严峻, 各类安全隐患层出不穷, 特别是利用递归解析服务器和域名体系展开的大规模网络攻击, 其攻击隐蔽难以被准确发现. 目前的研究工作主要基于恶意域名威胁情报库等单一信息来源进行大规模网络攻击检测, 难以全面挖掘网络攻击风险. 因此, 一方面未来需要进一步研究海量递归解析数据驱动的高伪装性和未知恶意域名检测技术, 不断扩充和完善恶意域名威胁情报库; 另一方面需要研究基于多源数据关联分析的网络攻击发现和预警技术, 挖掘递归解析服务的异常解析行为, 有助于保护递归解析服务系统的安全稳定运行.

5.4 递归解析服务安全风险的联合精准治理

递归解析服务规模庞大、分布广泛、风险治理难度大. 目前的研究工作主要采用分层非联动的风险处置方法, 例如仅通过在递归解析服务器上进行流量过滤和限速等方法处置 DDOS 等网络攻击, 然而当面临大规模网络攻击, 例如顶级权威服务器遭受来自递归的大规模攻击时, 现有递归侧处置方法将失效. 因此, 域名递归解析服务的安全风险治理不能仅通过递归侧进行, 还需要与域名体系和网络基础设施联动处置, 结合网络侧和权威侧的联动风险治理是一个极具应用价值的研究方向.

6 总 结

本文分析并分类阐述了 DNS 递归解析服务面临的具体安全问题,总结了共性的攻击原理、手段与特点.本文还聚焦学界提出的多样化安全防护策略,总结分析了其防护原理以及策略实施测量方法,并依照各策略的内在原理进行了分类,最后讨论了面对 DNS 递归解析服务的各类安全风险可能有效的安全防护策略集群.

本文还针对 DNS 递归解析服务安全问题,对该领域未来可能的研究热点问题、亟需进一步解决的安全问题等一一进行介绍,为未来 DNS 递归解析服务安全系统的建立和相关安全问题的研究提供参考.

作者贡献声明:李沁心完成了论文主体写作工作;武文浩、王兆华、李振宇提出指导意见并修改论文.

参 考 文 献

- [1] Mockapetris P V. RFC1034 Domain Names-Concepts and Facilities[S]. Fremont, CA: IETF Community, 1987
- [2] Mockapetris P V. RFC1035 Domain Names-Implementation and Specification[S]. Fremont, CA: IETF Community, 1987
- [3] Callejo P, Cuevas R, Vallina-Rodriguez N, et al. Measuring the global recursive DNS infrastructure: A view from the edge[J]. *IEEE Access*, 2019, 7: 168020-168028
- [4] Khormali A, Park J, Alasmay H, et al. Domain name system security and privacy: A contemporary survey[J]. *Computer Networks*, 2021, 185: 107699
- [5] van der Toorn O, Müller M, Dickinson S, et al. Addressing the challenges of modern DNS a comprehensive tutorial[J]. *Computer Science Review*, 2022, 45(1): 100-469
- [6] Grothoff C, Wachs M, Ermer M, et al. Toward secure name resolution on the Internet[J]. *Computers & Security*, 2018, 77: 694-708
- [7] Zou Futai, Zhang Siyu, Pei Bei, et al. Survey on domain name system security [C]//Proc of the 1st IEEE Int Conf on Data Science in Cyberspace (DSC). Piscataway, NJ: IEEE, 2016: 602-607
- [8] Kim T H, Reeves D. A survey of domain name system vulnerabilities and attacks[J]. *Journal of Surveillance, Security and Safety*, 2020, 1(1): 34-60
- [9] Schmid G. Thirty years of DNS insecurity: Current issues and perspectives[J]. *IEEE Communications Surveys & Tutorials*, 2021, 23(4): 2429-2459
- [10] Wang Wentong, Hu Ning, Liu Bo. Survey on technology of security enhancement for DNS[J]. *Journal of Software*, 2020, 31(7): 2205-2220 (in Chinese)
(王文通, 胡宁, 刘波, 等. DNS 安全防护技术研究综述[J]. *软件学报*, 2020, 31(7): 2205-2220)
- [11] Zhang Man, Yao Jiankang, Li Hongtao. Encryption technologies for DNS channel transmission: Status, trends and challenges[J]. *Journal of Software*, 2024, 35(1): 309-332 (in Chinese)
(张曼, 姚健康, 李洪涛, 等. DNS 信道传输加密技术: 现状, 趋势和挑战[J]. *软件学报*, 2024, 35(1): 309-332)
- [12] Zhang Bing, Zhang Yu, Zhang Weizhe. Study and analysis of recursive side DNS security[J]. *Journal of Software*, 2024, 35(10): 4876-4911
(张宾, 张宇, 张伟哲. 递归侧 DNS 安全研究与分析[J]. *软件学报*, 2024, 35(10): 4876-4911)
- [13] Moura G C M, Castro S, Hardaker W, et al. Clouding up the Internet: How centralized is DNS traffic becoming?[C]//Proc of the 20th ACM Internet Measurement Conf. New York: ACM, 2020: 42-49
- [14] Li Xiang, Lu Chaoyi, Liu Baojun, et al. The maginot line: Attacking the boundary of DNS caching protection [C]//Proc of the 32nd USENIX Security Symp. Berkeley, CA: USENIX Association, 2023: 3153-3170
- [15] Schomp K, Callahan T, Rabinovich M, et al. On measuring the client-side DNS infrastructure[C]//Proc of the 13th Conf on Int measurement Conf. New York: ACM, 2013: 77-90
- [16] Romain Fouchereau. Securing anywhere networking[EB/OL]. [2024-03-05]. https://efficientip.com/wp-content/uploads/2022/10/IDC-EUR149048522-EfficientIP-infobrief_FINAL.pdf
- [17] Journal Synthesis. China's cybersecurity events in 2014 [J]. *Secrecy*, 2015(1): 47-48 (in Chinese)
(本刊综合. 2014 年中国网络安全大事记 [J]. *保密工作*, 2015(1): 47-48)
- [18] Ameet Naik. Anatomy of a BGP hijack on Amazon's route 53 DNS service [EB/OL]. (2018-04-25)[2024-03-05]. <https://www.thousandeyes.com/blog/amazon-route-53-dns-and-bgp-hijack>
- [19] Operation Team. October 6th: DNS security incident statement & guide [EB/OL]. [2023-10-06]. <https://help.galxe.com/en/articles/8452958-october-6th-dns-security-incident-statement-guide>
- [20] Alharbi F, Chang Jie, Zhou Yuchen, et al. Collaborative client-side DNS cache poisoning attack [C]//Proc of the IEEE Conf on Computer Communications (INFOCOM 2019). Piscataway, NJ: IEEE, 2019: 1153-1161
- [21] Wikipedia Contributors. Dan Kaminsky[EB/OL]. [2024-03-05]. https://en.wikipedia.org/wiki/Dan_Kaminsky
- [22] Sun Hungmin, Chang Wenhuan, Chang Shihying, et al. DependDNS: Dependable mechanism against DNS cache poisoning [C]//Proc of the 8th Int Conf on Cryptology and Network Security (CANS 2009). Berlin: Springer, 2009: 174-188
- [23] Man Keyu, Qian Zhiyun, Wang Zhongjie, et al. DNS cache poisoning attack reloaded: Revolutions with side channels [C]//Proc of the 2020 ACM SIGSAC Conf on Computer and Communications Security. New York: ACM, 2020: 1337-1350
- [24] Zheng Xiaofeng, Lu Chaoyi, Peng Jian, et al. Poison over troubled

- forwarders: A cache poisoning attack targeting DNS forwarding devices [C]// Proc of the 29th USENIX Security Symp (USENIX Security 20). Berkeley, CA: USENIX Association, 2020: 577–593
- [25] Brandt M, Dai Tianxiang, Klein A, et al. Domain validation++ for mitm- resilient PKI[C]//Proc of the Conf on Computer and Communications Security (ACM SIGSAC 2018). New York: ACM, 2018: 2060–2076
- [26] Cho S, Fontugne R, Cho K, et al. BGP hijacking classification [C]//Proc of the 2019 Network Traffic Measurement and Analysis Conf (TMA 2019). Piscataway, NJ: IEEE, 2019: 25–32
- [27] Wikipedia Contributors. DNS hijacking[EB/OL]. [2024-03-05]. https://en.wikipedia.org/wiki/DNS_hijacking
- [28] Braun B. Investigating DNS hijacking through high frequency measurements[D]. San Diego: UC San Diego, 2016
- [29] Weaver N, Kreibich C, Paxson V. Redirecting DNS for ads and profit [C/OL]//Proc of the USENIX Workshop on Free and Open Communications on the Internet (FOCI 11). Berkeley, CA: USENIX Association, 2011[2024-03-05]. https://www.usenix.org/legacy/events/foci11/tech/final_files/Weaver.pdf
- [30] Tsai E, Kumar D, Raman R S, et al. CERTainty: Detecting DNS manipulation at scale using TLS certificates[J]. arXiv preprint, arXiv: 2305.08189, 2023
- [31] Pearce P, Jones B, Li F, et al. Global measurement of DNS manipulation [C]//Proc of the 26th USENIX Security Symp (USENIX Security 17). Berkeley, CA: USENIX Association, 2017: 307–323
- [32] Fejrskov M, Pedersen J M, Vasilomanolakis E. Detecting DNS hijacking by using NetFlow data [C]//Proc of the 2022 IEEE Conf on Communications and Network Security (CNS). Piscataway, NJ: IEEE, 2022: 273–280
- [33] Liu Baojun, Lu Chaoyi, Duan Haixin, et al. Who is answering my queries: Understanding and characterizing interception of the DNS resolution path [C]// Proc of the 27th USENIX Security Symp (USENIX Security 18). Berkeley, CA: USENIX Association, 2018: 1113–1128
- [34] Randall A, Liu Enze, Padmanabhan R, et al. Home is where the hijacking is: Understanding DNS interception by residential routers [C]//Proc of the 21st ACM Internet Measurement Conf. New York: ACM, 2021: 390–397
- [35] Radware. What is DNS flood attack (DNS flooding)[EB/OL]. [2024-03-05]. <https://www.radware.com/security/DDOS-knowledge-center/DDOSpedia/dns-flood/>
- [36] Bortzmeyer S, Huque S. RFC8020: NXDOMAIN: There Really is Nothing Underneath[S]. Fremont, CA: IETF Community, 2016
- [37] whatsmysdns. net. NXDOMAIN attacks[EB/OL]. [2024-03-05]. <https://www.whatsmysdns.net/dns-security/dns-attacks/nxdomain-attacks>
- [38] Li Weimin, Chen Luying, Lei Zhenming. Alleviating the impact of DNS DDOS attacks [C]//Proc of the 2nd Int Conf on Networks Security, Wireless Communications and Trusted Computing. Piscataway, NJ: IEEE, 2010: 240–243
- [39] Alieyan K, Kadhum M M, Anbar M, et al. An overview of DDOS attacks based on DNS [C]//Proc of the 2016 Int Conf on Information and Communication Technology Convergence (ICTC). Piscataway, NJ: IEEE, 2016: 276–280
- [40] Yazdani R, van Rijswijk-Deij R, Jonker M, et al. A matter of degree: Characterizing the amplification power of open DNS resolvers [C]//Proc of the 23rd Int Conf on Passive and Active Network Measurement(PAM 2022). Berlin: Springer, 2022: 293–318
- [41] Duan Huaiyi, Bearzi M, Vieli J, et al. CAMP: Compositional amplification attacks against DNS [C]//Proc of the 33rd USENIX Security Symp (USENIX Security 24). Berkeley, CA: USENIX Association, 2024: 5769–5786
- [42] Anagnostopoulos M, Kambourakis G, Gritzalis S, et al. Never say never: Authoritative TLD nameserver-powered DNS amplification [C/OL]//Proc of the 2018 IEEE/IFIP Network Operations and Management Symp. Piscataway, NJ: IEEE, 2018[2024-03-05]. https://ieeexplore.ieee.org/stamp/stamp.jsp?arnumber=8406224&asa_token=i0ocXejqPzYAAAAA:7FixmD7NWvuKbHLvZrqk7tIisTx0whU-ZayJOiGDI5ZxdwehPvop1x1S9QOqMRZ8wb2WdtYrVFo
- [43] Nawrocki M, Jonker M, Schmidt T C, et al. The far side of DNS amplification: Tracing the DDoS attack ecosystem from the Internet core[C]// Proc of the 21st ACM Internet Measurement Conf. New York: ACM, 2021: 419–434
- [44] Nosyk Y, Korczyński M, Duda A. Routing loops as mega amplifiers for dns-based ddos attacks[C]//Proc of the 23rd Int Conf on Passive and Active Network Measurement. Berlin: Springer, 2022: 629–644
- [45] Wikipedia Contributors. DNS flood[EB/OL]. [2024-03-05]. https://en.wikipedia.org/wiki/DNS_Flood
- [46] RSD attack. Cyberattack[EB/OL]. [2024-03-05]. <https://cybatk.com/2017/03/25/rsd-attack/>
- [47] Afek Y, Bremner-Barr A, Shafir L. NXNSAttack: Recursive DNS inefficiencies and vulnerabilities [C]//Proc of the 29th USENIX Security Symp (USENIX Security 20). Berkeley, CA: USENIX Association, 2020: 631–648
- [48] Sommese R, Claffy K C, van Rijswijk-Deij R, et al. Investigating the impact of DDOS attacks on DNS infrastructure [C]//Proc of the 22nd ACM Internet Measurement Conf. New York: ACM, 2022: 51–64
- [49] Allor P, Armstrong K, Beardsley T, et al. CVE[EB/OL]. [2024-03-05]. <https://cve.mitre.org/>
- [50] Venustech. DNSpooq series vulnerability analysis and Reproof [EB/OL]. [2024-03-05]. https://www.venustech.com.cn/new_type/aqldfx/20210201/22352.html
- [51] CVEdetails. Vulnerability details : CVE–2020–8616[EB/OL]. [2024-03-05]. <https://www.cvedetails.com/cve/CVE-2020-8616/?q=CVE-2020-8616>
- [52] CVEdetails. Nginx DNS resolver vulnerability (CVE–2021–23017) problem fix[EB/OL]. [2024-03-05]. https://blog.csdn.net/qq_42534026/article/details/117354728
- [53] CVEdetails. Vulnerability details : CVE–2022–0635[EB/OL]. [2024-03-05]. <https://www.cvedetails.com/cve/CVE-2022-0635/?q=CVE->

- 2022-0635
- [54] Zhu Liang, Hu Zi, Heidemann J, et al. Connection-oriented DNS to improve privacy and security [C]//Proc of the 2015 IEEE Symp on Security and Privacy. Piscataway, NJ: IEEE, 2015: 171–186
- [55] Hu Zi, Zhu Liang, Heidemann J, et al. RFC7858: Specification for DNS over Transport Layer Security (TLS)[S]. Fremont, CA: IETF Community, 2016
- [56] Reddy T, Wing D, Patil P. RFC8094 DNS over Datagram Transport Layer Security (DTLS)[S]. Fremont, CA: IETF Community, 2017
- [57] Houser R, Li Zhou, Cotton C, et al. An investigation on information leakage of DNS over TLS [C]//Proc of the 15th Int Conf on Emerging Networking Experiments and Technologies. New York: ACM, 2019: 123–137
- [58] Hoffman P, McManus P. RFC8484 DNS Queries over HTTPS (DoH)[S]. Fremont, CA: IETF Community, 2018
- [59] Hounsel A, Borgolte K, Schmitt P, et al. Comparing the effects of DNS, DoT, and DoH on web performance [C]//Proc of the Web Conf 2020. New York: ACM, 2020: 562–572
- [60] Huitema C, Dickinson S, Mankin A. RFC9250 DNS over Dedicated QUIC Connections[S]. Fremont, CA: IETF Community, 2022
- [61] Batenburg B. Performance of DNS over QUIC[D]. Enschede: University of Twente, 2022
- [62] Lyu M, Gharakheili H H, Sivaraman V. A survey on DNS encryption: Current development, malware misuse, and inference techniques[J]. ACM Computing Surveys, 2022, 55(8): Article 162
- [63] Badhwar R. Domain Name System (DNS) Security [M]//The CISO's Next Frontier: AI, Post-Quantum Cryptography and Advanced Security Paradigms. Berlin: Springer, 2021: 207–212
- [64] Hu Guannan, Fukuda K. An analysis of privacy leakage in DoQ traffic [C]//Proc of the CoNEXT Student Workshop. New York: ACM, 2021: 7–8
- [65] hvt.DNSCrypt[EB/OL]. [2024-03-05]. <https://github.com/DNSCrypt/dnscrypt-protocol/blob/master/DNSCRYPT-V2-PROTOCOL.txt>
- [66] Andrews M. RFC7873 Domain Name System (DNS) Cookies[S]. Fremont, CA: IETF Community, 2016
- [67] Sury O, Toorop W, Eastlake 3rd D, et al. RFC9018 Interoperable Domain Name System (DNS) Server Cookies[S]. Fremont, CA: IETF Community, 2021
- [68] Dickson B. Authenticated DNS over TLS to authoritative servers[EB/OL]. [2024-03-05]. <https://www.ietf.org/archive/id/draft-dickson-dprive-aDoTauth-06.html>
- [69] Bernstein D. Curve25519: High-speed elliptic-curve cryptography [EB/OL]. [2024-03-05]. <https://cr.yp.to/ecdh.html>
- [70] Wikipedia Contributors. DNSCurve[EB/OL]. [2024-03-05]. <https://en.wikipedia.org/wiki/DNSCurve>
- [71] DNSCurve. org. Introduction to DNSCurve[EB/OL]. [2024-03-05]. <https://dnscurve.org/>
- [72] Cooper A, Tschofenig H, Aboba B, et al. RFC6973 Privacy Considerations for Internet Protocols[S]. Fremont, CA: IETF Community, 2013
- [73] Bortzmeyer S, Dolmans R, Hoffman P. RFC9156 DNS Query Name Minimisation to Improve Privacy[S]. Fremont, CA: IETF Community, 2021
- [74] Bortzmeyer S. RFC7816: DNS Query Name Minimisation to Improve Privacy[S]. Fremont, CA: IETF Community, 2016
- [75] Verisign Labs. Query name minimization and authoritative DNS server behavior[EB/OL]. [2024-03-05]. <https://indico.dns-oarc.net/event/21/contributions/298/attachments/267/487/qname-min.pdf>
- [76] Arends R, Austein R, Larson M, et al. RFC4033 DNS Security Introduction and Requirements[S]. Fremont, CA: IETF Community, 2005
- [77] Laurie B, Sisson G, Arends R, et al. RFC5155 DNS Security (DNSSEC) Hashed Authenticated Denial of Existence[S]. Fremont, CA: IETF Community, 2008
- [78] van Adrichem N L M, Blenn N, Lúa A R, et al. A measurement study of DNSSEC misconfigurations[J/OL]. Security Informatics, 2015 [2024-03-05]. <https://link.springer.com/content/pdf/10.1186/s13388-015-0023-y.pdf>
- [79] Herzberg A, Shulman H. DNSSEC: Security and availability challenges [C]//Proc of the 2013 IEEE Conf on Communications and Network Security (CNS). Piscataway, NJ: IEEE, 2013: 365–366
- [80] Dagon D, Antonakakis M, Day K, et al. Recursive DNS architectures and vulnerability Implications [C/OL]//Proc of the NDSS. Reston, VA: The Internet Society, 2009[2024-03-05]. https://coeus-center.com/articles/recursive_dns_architectures.pdf
- [81] Hubert A, van Mook R. RFC5452 Measures for Making DNS More Resilient Against Forged Answers[S]. Fremont, CA: IETF Community, 2009
- [82] Chandramouli R, Rose S. Secure domain name system (DNS) deployment guide[J/OL]. NIST Special Publication, 2006, 800[2024-03-05]. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-81-2.pdf>
- [83] Senie D. RFC2827 Network Ingress Filtering: Defeating Denial of Service Attacks which Employ IP Source Address Spoofing[S]. Fremont, CA: IETF Community, 2000
- [84] Baker F, Savola P. RFC3704 Ingress Filtering for Multihomed Networks [S]. Fremont, CA: IETF Community, 2004
- [85] Vixie P, Schryver V. DNS response rate limiting (DNS RRL) [EB/OL]. [2024-03-05]. <http://ss.vix.su/~vixie/isc-tn-2012-1.txt>
- [86] Rossow C. Amplification hell: Revisiting network protocols for DDOS abuse [C/OL]//Proc of the NDSS. Reston, VA: The Internet Society, 2014[2024-03-05]. https://dud.inf.tu-dresden.de/~strufe/rn_lit/rossow14amplification.pdf
- [87] BlueKrypt. Cryptographic key length recommendation[EB/OL]. [2024-03-05]. <https://www.keylength.com/en/4/>
- [88] BlueKrypt. Cryptographic key length recommendation[EB/OL]. [2024-03-05]. <https://www.keylength.com/en/3/>
- [89] Perdisci R, Antonakakis M, Luo Xiapu, et al. WSEC DNS: Protecting recursive DNS resolvers from poisoning attacks [C]//Proc of the 2009 IEEE/IFIP Int Conf on Dependable Systems & Networks. Piscataway, NJ: IEEE, 2009: 3–12
- [90] Nosyk Y, Lone Q, Zhauniarovich Y, et al. Intercept and inject: DNS

- response manipulation in the wild [C]//Proc of the 24th Int Conf on Passive and Active Network Measurement. Berlin: Springer, 2023: 461–478
- [91] Hardaker W. Analyzing and mitigating privacy with the DNS root service [C/OL]//Proc of the NDSS: DNS Privacy Workshop. Reston, VA: The Internet Society, 2018[2024-03-05]. <https://ant.isi.edu/~hardaker/papers/2018-02-ndss-analyzing-root-privacy.pdf>
- [92] Dai Tianxiang, Jeitner P, Shulman H, et al. From IP to transport and beyond: Cross-layer attacks against applications [C]//Proc of the 2021 ACM SIGCOMM. New York: ACM, 2021: 836–849
- [93] Kaminsky D. Black ops 2008: It's the end of the cache as we know it [EB/OL]. [2024-03-05]. <https://www.blackhat.com/presentations/bh-jp-08/bh-jp-08-Kaminsky/BlackHat-Japan-08-Kaminsky-DNS08-BlackOps.pdf>
- [94] Trostle J, van Besien B, Pujari A. Protecting against DNS cache poisoning attacks [C]//Proc of the 6th IEEE Workshop on Secure Network Protocols. Piscataway, NJ: IEEE, 2010: 25–30
- [95] Luo Jing. The latest DGA malicious domain name detection method in 2021 (with Python code) [EB/OL]. [2024-03-05]. <https://bbs.huaweicloud.com/blogs/detail/264516>
- [96] Turner A, Athapathu R, Kharbanda C. Evaluating QUIC for privacy improvements over its predecessors [EB/OL]. [2024-03-05]. <https://allison-turner.github.io>
- [97] Hoang N P, Polychronakis M, Gill P. Measuring the accessibility of domain name encryption and its impact on Internet filtering [C]//Proc of the 23rd Int Conf on Passive and Active Network Measurement. Berlin: Springer, 2022: 518–536
- [98] Alowaisheq E, Tang Siyuan, Wang Zhihao, et al. Zombie awakening: Stealthy hijacking of active domains through DNS hosting referral [C]//Proc of the 2020 ACM SIGSAC Conf on Computer and Communications Security. New York: ACM, 2020: 1307–1322
- [99] Akiwate G, Sommesse R, Jonker M, et al. Retroactive identification of targeted DNS infrastructure hijacking [C]//Proc of the 22nd ACM Internet Measurement Conf. New York: ACM, 2022: 14–32
- [100] Fujiwara K, Kato A, Kumari W. RFC8198 Aggressive Use of DNSSEC-Validated Cache[S]. Fremont, CA: IETF Community, 2017
- [101] Damas J, Neves F. RFC5358 Preventing Use of Recursive Nameservers in Reflector Attacks[S]. Fremont, CA: IETF Community, 2008
- [102] Wikipedia Contributors. DNSCrypt [EB/OL]. [2024-03-05]. <https://en.wikipedia.org/wiki/DNSCrypt>
- [103] Davis J. The DNS bake sale: Advertising DNS cookie support for DDOS protection[D]. Provo: Brigham Young University, 2021
- [104] Rajendran B. DNS amplification & DNS tunneling attacks simulation, detection and mitigation approaches [C]//Proc of the 2020 Int Conf on Inventive Computation Technologies (ICICT). Piscataway, NJ: IEEE, 2020: 230–236
- [105] Lu Keyu, Li Zhengmin, Zhang Zhaoxin, et al. DNS recursive server health evaluation model [C/OL]//Proc of the 18th Asia-Pacific Network Operations and Management Symp (APNOMS). Piscataway, NJ: IEEE, 2016[2024-03-05]. https://ieeexplore.ieee.org/stamp/stamp.jsp?arnumber=7737281&casa_token=wnW5NSnV4hUAAAAA:xF6Bq9m9tzUywtG08EBiTdzZKpKRnbd6zPIXxR-10vbnKUUDX476jQBkeAfb2aPEXMIRIbMeFc
- [106] Goldlust S, Almond C. How do I restrict only remote users from looking up the server version? [EB/OL]. [2024-03-05]. <https://kb.isc.org/docs/aa-00308>
- [107] Davis J, Deccio C. A peek into the DNS cookie jar: An analysis of DNS cookie use [C]//Proc of the 22nd Int Conf on Passive and Active Network Measurement. Berlin: Springer, 2021: 302–316
- [108] Lu Chaoyi, Liu Baojun, Li Zhou, et al. An end-to-end, large-scale measurement of DNS-over-encryption: How far have we come? [C]//Proc of the 19th Internet Measurement Conf. New York: ACM, 2019: 22–35
- [109] Chhabra R, Murley P, Kumar D, et al. Measuring DNS-over-HTTPS performance around the world [C]//Proc of the 21st ACM Internet Measurement Conf. New York: ACM, 2021: 351–365
- [110] Kosek M, Doan T V, Grandearth M, et al. One to rule them all? A first look at DNS over quic [C]//Proc of the 22nd Int Conf on Passive and Active Network Measurement. Berlin: Springer, 2022: 537–551
- [111] Koshy A M, Yellur G, Kammachi H J, et al. An insight into encrypted DNS protocol: DNS over TLS [C]//Proc of the 4th Int Conf on Recent Developments in Control, Automation & Power Engineering (RDCAPE). Piscataway, NJ: IEEE, 2021: 379–383
- [112] Vekshin D, Hynek K, Cejka T. DoH insight: Detecting DNS over https by machine learning [C/OL]//Proc of the 15th Int Conf on Availability, Reliability and Security. New York: ACM, 2020[2024-03-05]. https://dl.acm.org/doi/pdf/10.1145/3407023.3409192?casa_token=5zTRxSHZ40YAAAAA:o9HHbXL9KKCISwL07f_UkFrmCKXK7Ev-8bJ4B-Td3TukMOvhkPTCqOf6HzIMUZ72yQ5xHdFN0-AWMQ
- [113] Takano Y, Ando R, Takahashi T, et al. A measurement study of open resolvers and DNS server version [C/OL]//Proc of the Internet Conf IEICE. Piscataway, NJ: IEEE, 2013[2024-03-05]. <https://www.internetconference.org/ic2013/PDF/ic2013-paper01.pdf>
- [114] Lu Keyu. Design and implementation of a DNS recursive server recommendation system [D]. Harbin: Harbin Institute of Technology, 2015 (in Chinese)
(陆柯羽. DNS 递归解析服务器推荐系统设计与实现 [D]. 哈尔滨: 哈尔滨工业大学, 2015)
- [115] MacFarland D C, Shue C A, Kalafut A J. Characterizing optimal DNS amplification attacks and effective mitigation [C]//Proc of the 16th Int Conf on Passive and Active Measurement. Berlin: Springer, 2015: 15–27
- [116] Deccio C, Argueta D, Demke J. A quantitative study of the deployment of DNS rate limiting [C]//Proc of the 2019 Int Conf on Computing, Networking and Communications (ICNC). Piscataway, NJ: IEEE, 2019: 442–447
- [117] Chen Yidan, Li Fujuan. Research on security of digital certificate [J]. Journal of Information Research, 2021, 7(9): 836–843 (in Chinese)
(陈怡丹 李馥娟. 数字证书安全性研究 [J]. 信息安全研究, 2021, 7(9): 836–843)
- [118] Wander M. Measurement survey of server-side DNSSEC adoption

- [C/OL]//Proc of the 2017 Network Traffic Measurement and Analysis Conf. Piscataway, NJ: IEEE, 2017[2024-03-05]. https://ieeexplore.ieee.org/stamp/stamp.jsp?arnumber=8002913&casa_token=LgIplHGNSwPgAAAAA:2YFrNJv2Bp8T5n0J6PiN214AbOask5jtPpFzWTZHzirxSko7NN2FZP6iZvM9TFj9EIkEo3jZwRw
- [119] de Vries W B, Scheitle Q, Müller M, et al. A first look at QNAME minimization in the domain name system [C]//Proc of the 20th Int Conf on Passive and Active Measurement. Berlin: Springer, 2019: 147–160
- [120] Hilton A, Deccio C, Davis J. Fourteen years in the life: A root server's perspective on DNS resolver security [C/OL]//Proc of the 32nd USENIX Security Symp. Berkeley, CA: USENIX Association, 2023[2024-03-05]. <https://www.usenix.org/system/files/usenix-security23-hilton.pdf>
- [121] Dagon D, Antonakakis M, Vixie P, et al. Increased DNS forgery resistance through 0x20-bit encoding: Security via leet queries [C]//Proc of the 15th ACM Conf on Computer and Communications Security. New York: ACM, 2008: 211–222
- [122] Vyshnevskiy I. DNS and the bit 0x20[EB/OL]. [2024-03-05]. <https://hypothetical.me/short/dns-0x20/>
- [123] Vyshnevskiy I. DNS resolver advanced options[EB/OL]. [2024-03-05]. <https://hypothetical.me/short/dns-0x20/>
- [124] CZ. NIC. Knot resolver 1.1. 0 release, August 2016[EB/OL]. [2024-03-05]. <https://knotresolver.readthedocs.io/en/stable/NEWS.html#knotresolver-1-1-0-2016-08-12>
- [125] Rukhin A, Soto J, Nechvatal J, et al. A Statistical Test Suite for Random and Pseudorandom Number Generators for Cryptographic Applications[M]. Gaithersburg: US Department of Commerce, Technology Administration, National Institute of Standards and Technology, 2001
- [126] Wang Yongge, Nicol T. Statistical properties of pseudo random sequences and experiments with PHP and Debian OpenSSL [C]//Proc of the 19th Computer European Symp on Research in Computer Security. Berlin: Springer, 2014: 454–471
- [127] Wikipedia Contributors. Wald–Wolfowitz runs test[EB/OL]. [2024-03-05]. https://en.wikipedia.org/wiki/Wald-Wolfowitz_runs_test
- [128] Wikipedia Contributors. Spectral test[EB/OL]. [2024-03-05]. https://en.wikipedia.org/wiki/Spectral_test
- [129] Wikipedia Contributors. Pearson's chi-squared test[EB/OL]. [2024-03-05]. https://en.wikipedia.org/wiki/Pearson%27s_chi-squared_test
- [130] Korczyński M, Nosyk Y, Lone Q, et al. Inferring the deployment of inbound source address validation using DNS resolvers [C]//Proc of the Applied Networking Research Workshop. New York: ACM, 2020: 9–11
- [131] MANRS. Mutually agreed norms for routing security[EB/OL]. [2024-03-05]. <https://www.manrs.org/>
- [132] Lone Q, Luckie M, Korczyński M, et al. Using loops observed in traceroute to infer the ability to spoof [C]//Proc of the 18th Int Conf on Passive and Active Measurement. Berlin: Springer, 2017: 229–241
- [133] Korczyński M, Nosyk Y, Lone Q, et al. Don't forget to lock the front door! inferring the deployment of source address validation of inbound traffic [C]//Proc of the 21st Int Conf on Passive and Active Measurement (PAM 2020). Berlin: Springer, 2020: 107–121
- [134] Spoofer Project. The Spoofer Project[EB/OL]. [2024-03-05]. <https://www.caida.org/projects/spoofer/>



Li Qinxin, born in 2000. Master candidate. Her main research interests include network measurement and cyberspace security.

李沁心, 2000年生. 硕士研究生. 主要研究方向为网络测量和网络空间安全.



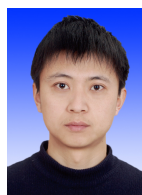
Wu Wenhao, born in 2000. Master candidate. His main research interests include network measurement and network security.

武文浩, 2000年生. 硕士研究生. 主要研究方向为网络测量、网络安全.



Wang Zhaohua, born in 1994. PhD, Postdoc. Her main research interests include network measurement and data center networks.

王兆华, 1994年生. 博士, 博士后. 主要研究方向为网络测量、数据中心网络.



Li Zhenyu, born in 1980. PhD, professor, PhD supervisor. His main research interests include network transmission, network measurement, and artificial intelligence in network.

李振宇, 1980年生. 博士, 研究员, 博士生导师. 主要研究方向为网络传输、网络测量、网络人工智能.